
Cyberboswachters Light

De beste digitale stropers zijn ook de beste cyberboswachters

Dams Tim



Inhoudsopgave

1	Introductie	1
1.1	Boswachters en stropers	1
1.2	Dankwoord	1
1.3	Waarschuwingen	2
2	Wordt het erger?	3
2.1	Het voorbije decennium	3
2.2	2020: De macht van sociale media	15
2.3	2022: Oorlog en AI	16
2.4	Het is erger, maar...	19
3	Cybersecurity fundamenteën	21
3.1	CIA en het security model	21
3.2	Een ongelijke strijd	23
3.3	Wie zijn de stropers?	24
3.4	Hoe vallen ze aan?	29
3.5	Classificatie van aanvallen	30
3.6	Hoe verdedigen	36
3.7	Social Engineering	37
3.8	Soorten aanvallen	39
4	GDPR	51
4.1	Wat omvat GDPR?	51
4.2	Hoe beschermt GDPR mij als burger?	52
4.3	Wat beschermt GDPR?	53
4.4	Persoonlijke data buiten EU	53
4.5	Meldplicht datalekken	54
4.6	Boetes	56
4.7	Conclusie	57
5	Appendix 1: Meer weten	59
5.1	Nieuws en blogartikels	59

5.2	Podcasts	59
5.3	Tutorials	59
6	Appendix 2: Dark web	61
6.1	Kenmerken van het Darkweb	62
6.2	Waarom bestaat het Darkweb?	62
6.3	Toegang tot het Darkweb: TOR	63
6.4	TOR heeft ook nadelen:	63
6.5	Waarom moet je dit nu weten?	63
7	Appendix 3: Cybersecurity Awareness creëren	65
7.1	Waarom awareness?	65
7.2	Awareness-campagnes	66
7.3	Praktische best practices	68
7.4	Incident response	69
7.5	Social engineering en phishing	71

1 Introductie

Dit is de *light* versie van het handboek dat wordt gebruikt als basis-cursus binnen de opleidingen elektronica-ict en toegepaste informatica van de AP Hogeschool. Het heeft als doel een breed overzicht te geven van de *wereld van de cybersecurity*. Het doel is niet alomvattend te zijn, maar vooral om mensen zin te geven om meer te weten te komen over deze belangrijke én boeiende wereld. In tegenstelling tot de *volledige editie* gaat deze versie er niet eisen dat de lezer minimale voorkennis heeft inzake ICT, netwerken, etc.

Merk op dat dit de prille eerste editie van de *light* versie is. Hij is dus ook verre van compleet. Opmerkingen en feedback zijn dus zeker welkom! Interesse in het volledige handboek? Je kan [deze hier kopen](#).

1.1 Boswachters en stropers

De subtitel, “*De beste digitale stropers zijn ook de beste cyberboswachters*”, van dit handboek verdient een extra woordje uitleg. Dit boek zal zeker niet de obscure wereld van de hackers en cybercriminelen verheerlijken, integendeel. We willen echter wel tonen hoe de stropers, de slechterikken in dit boek, te werk gaan, opdat het ons zo een beter beeld geeft waar we ons tegen moeten beschermen als goede cyberboswachters.

1.2 Dankwoord

Dank aan (soms al oud-)studenten Ernie de Magtige, Dimitriy Vassilchenko, Jasper Van Meel en Erik Van Dyck om als externe fact- en spellingcheckers aardig wat (*gênante*) foutjes en typos te ontdekken.

Een oprechte dank aan Stefaan Somerling (RealDolmen) voor de feedback op het hoofdstuk omtrent GDPR. Geef gerust een sein als u, conform de GDPR wetgeving, liever uw naam niet in dit document ziet staan ;).

Een dikke fist bump voor collega en *brother from another mother* Koen Van Eyken, die een deel van z’n paasvakantie opofferde om met een kritische blik door dit boek te gaan! Uiteraard ook een dikke merci

aan de collega's die feedback op dit document hebben gegeven, en dan zeker aan Michael Boeynaems en Serge Horsmans.

1.3 Waarschuwingen

Dit brengt ons automatisch bij een belangrijke waarschuwing: je zal in dit handboek geregeld technieken en tools tegenkomen die verregaande gevolgen voor derden én jezelf kunnen hebben indien ze misbruikt worden. We tonen deze zaken enkel vanuit het standpunt dat zonet werd besproken: digitale stropers zijn de beste cyberboswachters. Het is belangrijk dat je begrijpt dat je deze tools en technieken NOOIT of te NIMMER voor kwade doeleinden mag gebruiken. Het is zelfs zo dat het gebruik van veel van deze zaken strafrechtelijke gevolgen kunnen hebben, inclusief boetes tot zelfs jarenlange opsluiting.

Indien je dus deze tools of technieken wenst te gebruiken dan mag dit enkel op volgende doelwitten:

- Zaken waar jij de eigenaar van bent. Denk aan servers, webpagina's, gebruikers, etc.
- Op doelwitten waar je geen eigenaar van bent, maar waar je wel expliciete toestemming voor hebt gekregen.

1.3.1 Opletten met experimenten

Indien je van plan bent om met bepaalde tools te experimenteren, hou dan rekening met volgende tips:

- Werk zoveel mogelijk met virtuele machines en test nooit op een *live systeem* indien daar geen erg goede reden voor is.
- Hou er rekening mee dat bepaalde tools permanente "gaten" slagen in je systemen. Deze kunnen dus na (of tijdens!) je experimenten door digitale stropers misbruikt worden.

2 Wordt het erger?

Het laatste decennium jaar is de (cyber)security wereld erg veranderd. Ze doet dit niet omdat ze daar zin in heeft, maar wel als antwoord op wat er gebeurt in de wereld omtrent cyberaanvallen, geopolitieke situaties, etc.

Het is altijd een kat en muisspel, waarbij de boswachters helaas bijna altijd zullen achterlopen op de stropers. De kwaadwillige hackers hoeven maar één klein gaatje te vinden in je peperdure beveiliging en ze zijn binnen. Terwijl jij als boswachter wel aan alles moet (proberen te) denken. Dat het erger wordt, is eigenlijk daarom bijna automatisch een evidentie. De wereld van de beveiliging gebeurt per opbod en hoe beter de boswachters het bos kunnen verdedigen, hoe complexer de technieken zullen worden die de stropers hanteren.

In de volgende secties geven we een klein historisch overzicht van enkele belangrijke, interessante of spectaculaire gebeurtenissen die hebben plaatsgevonden in de cyberwereld de voorbije jaren. Dit laat ons toe om enerzijds enkele begrippen te duiden, anders om de vraag “wordt het erger?” te beantwoorden.



We gebruiken de term cyber om alles aan te duiden dat zich afspeelt op de digitale snelweg, namelijk het Internet, de *cloud*, het *www*, en alle synoniemen en aanverwanten.

2.1 Het voorbije decennium

We zullen geregeld terug in de tijd gaan om te bekijken hoe bepaalde cyberverdedigings- en aanvalstechnieken zijn ontstaan, maar in dit hoofdstuk gaan we enkel terug tot 2010. Het jaar waarin Mark Zuckerberg, CEO van Facebook, door Time Magazine tot persoon van het jaar werd uitgeroepen en ook waarin Apple de eerste iPad tablet aan het publiek toonde. Het was helaas ook het jaar waarin het boorplatform, Deepwater Horizon, voor één van de ergste milieurampen ooit zorgde, alsook het jaar dat 33 mijnwerkers anderhalve maand lang 700 meter diep opgesloten zaten in een mijn. Voor ons, als toekomstige cyberboswachters, is echter de meest cruciale gebeurtenis het ontdekken van **Stuxnet**.

2.1.1 Voor 2010



Figuur 2.1: “Het aardse paradijs met de zondeval van Adam en Eva” door Peter Paul Rubens en Jan Brueghel (de Oude). Duidelijk gebaseerd op een wereld van voor 2010.

Voor het ontdekken van Stuxnet in 2010 leek de cyberbeveiligingswereld wel een wereld van (relatieve) peis en vree. Het ergste dat kon gebeuren was dat je computer een virusje opdeed waardoor je mogelijk wat data, en vooral veel werkuren, kwijt raakte. Virussen, wormen en spam waren alomtegenwoordig maar waren eigenlijk niet meer dan luizen in de pels van de eindgebruikers. Tuurlijk, er werd een grondig gevloekt als een virus je foto's verwijderde of wanneer een worm zichzelf verspreidde naar je contacten - denk maar aan het *ILOVEYOU* virus dat als een soort *social engineer* mensen deed geloven dat ze een potentiële liefdesmatch hadden waarop ze vol spanning de bijlage openden en zo de worm *in huis haalden*. Of wat te denken van de *Conficker* worm die in 2008 meer dan 3 miljoen systemen kon besmetten en telkens de update-services van het Windows toestel uitschakelde. Uiteraard, dat was irritant, maar menig mens zou maar al te graag terug naar die tijd willen gaan als daarmee ransomware, botnets en door overheden gesponsorde cyberaanvallen onbestaande zouden zijn.



De termen worm, virus en malware zullen geregeld door elkaar worden gebruikt in deze cursus. Alle drie betekenen net niet hetzelfde, maar toch:

- Een **virus** is een kwaadaardig programma dat, eens het op een computer of apparaat staat, digitale schade kan aanbrengen.
- Een **worm** daarentegen is ook een virus, maar eentje dat zichzelf kan *voortplanten* naar andere systemen, iets wat een virus niet kan. Een worm kan zichzelf dus verspreiden zonder menselijke hulp.
- **Malware** is een overkoepelende term voor alle programma's en code die digitale schade aan een systeem of netwerk brengen. Virussen en wormen behoren dus tot deze groep.

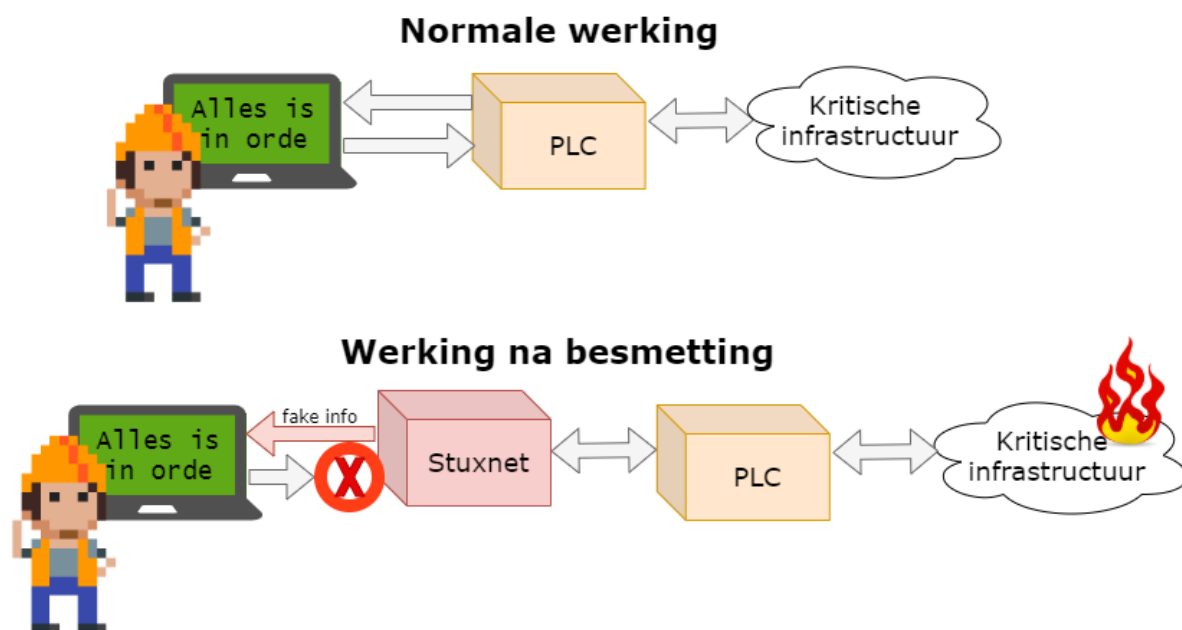
Naast deze drie termen zullen we ook nog enkele andere malware types tegenkomen zoals Adware, spyware, spam, trojans, backdoors en rootkit. Wanneer nodig zullen we deze termen toelichten. Onthoud nu alvast dat malware de algemene naam is voor alle malafide software.

2.1.2 2010: En dan verscheen Stuxnet

Virussen konden computers (tijdelijk) onbruikbaar maken. OK, lastig, maar niet het einde van de wereld. De Stuxnet worm die in 2010 plots op de radar verscheen kon dat potentieel wel: de wereld beëindigen! Het was een worm die op maat was gemaakt om zogenaamde **PLCs** (*Programmable Logic Controllers*) te controleren. Héél veel van onze kritische infrastructuur is geautomatiseerd met behulp van deze PLCs, krachtige apparaten die machines kunnen aansturen zoals liften, robotarmen aan assemblagelijnen, zuiveringsinstallaties en zelfs kernreactors. PLCs vormen de interface tussen machines (hardware) en de computers (met software op) die de operatoren gebruiken om deze machines opdrachten te geven. Operators kunnen op hun systemen de machines bedienen en te allen tijde controleren of deze naar behoren werken.

Wat Stuxnet deed was zich tussen de hardware en de software nestelen. Als een worm besmette het laptops en computers en zocht het of er PLC-bedieningssoftware aanwezig was op het toestel. Als dat het geval was dan plaatste het zichzelf er tussen in zodat het:

1. de machines opdrachten kon geven zonder dat de operator dit wist.
2. aan de operator kon vertellen dat alles in orde was, terwijl in realiteit de PLC mogelijk desastreuze opdrachten aan de hardware gaf.



Figuur 2.2: Werking stuxnet.

We moeten er geen tekeningetje bij maken wat de effecten kunnen zijn indien een Stuxnet variant bewust werd ingezet om bijvoorbeeld de machinerie in een kerncentrale of waterdam te saboteren. Zonder in details van Stuxnet in te gaan is het duidelijk dat het verschijnen van dit virus een ommekeer betekende qua potentiële gevolgen van een cyberaanval: mensenlevens stonden plots op het spel, niet enkel onze dierbare e-mails en digitale vakantiefoto's.



Stuxnet bleek een worm te zijn die probeerde een specifiek soort centrifuge te saboteren: namelijk de centrifuges die Iran gebruikte om uranium te verrijken. De inlichtingendiensten van de Verenigde Staten en Israël zouden klaarblijkelijk Stuxnet hebben ontworpen om zo dit verrijkkingsproces van uranium in Iran te dwarsbomen.



Wens je meer te weten over Stuxnet? Dan raden we je de uitstekende, in 2016 verschenen, documentaire “Zero Days” door Alex Gibney aan. Deze documentaire geeft een zeer ontluisterend én boeiend beeld over de zoektocht naar de oorsprong van het Stuxnet virus.

2.1.3 2013: Onze privacy te grabbel gegooid

Surfen op het Internet was altijd een risico. We wisten in 2013 al lang dat onze datapakketjes over tientallen apparaten doorheen het Internet worden getransporteerd om zo tot bij hun doel te geraken. Cookies volgden al geregeld onze stappen en ook de aanbevelingen van Amazon waren soms akelig accuraat. Dat was de prijs die we moesten betalen om de ontelbare bronnen van het Internet te kunnen gebruiken. En als je echt wat meer privacy nodig had, dan schakelde je de “incognito” modus in van je browser. Maar ook dan was je je ervan bewust dat zelfs je ISP (*Internet service provider*, zoals Telenet of Proximus) en je doel konden meekijken. Hoe erg kan dat zijn?

Die gedachte leefde bij veel mensen tot dan: het Internet was een nuttige tool en je wist dat er kon meegekeken worden door *derden* als ze dat echt wilden. Maar zou dit nu echt consequent en op grote schaal gebeuren? Neen toch?!

Dat glazen huisje werd in 2013 hardhandig aan diggelen geslagen door twee belangrijke personen:

- **Edward Snowden:** als (contractueel ingehuurd) systeembeheerder bij de NSA, de Amerikaanse inlichtingendienst gericht op elektronische spionage, had hij toegang tot het doen en laten van de dienst. Snowden lekte een grote hoeveelheid top-secret documenten naar de bevolking die onder andere het *PRISM*-programma uit de doeken deed. Hieruit bleek dat de NSA een complexe samenwerking had met enkele grote Amerikaanse Internetbedrijven (o.a. Microsoft, Google, Facebook, Apple, etc.) die zogenaamde *taps* op hun systemen hebben staan zodat de NSA “kan meeluisteren” op de netwerken.
- **Julian Assange:** er zijn altijd klokkenluiders (*whistleblowers*) geweest die om persoonlijke overtuigingen vonden dat bepaalde informatie met het publiek moesten worden gedeeld. Zeker in dictatoriale middens kan dit levensgevaarlijk zijn. Aan het eind van de 20e eeuw kregen deze klokkenluiders echter een krachtig apparaat om hun nieuws veilig te verspreiden: het Internet. Julian Assange beseftte dit en richtte daarom in 2006 Wikileaks op. Een site waar klokkenluiders op een anonieme manier documenten konden *leken*. Tot 2010 zijn zo enkele erg controversiële documenten met de wereld gedeeld die soms verregaande diplomatieke of geopolitieke gevolgen hadden. Het lot van Assange is nog steeds onduidelijk: momenteel wordt hij in het Verenigd Koninkrijk in hechtenis gehouden en voert hij hevig strijd (via de rechtbank) om niet uitgeleverd te worden aan de Verenigde Staten.



Het is niet evident om over mensen als Assange en Snowden te praten zonder in een controversiële modderpoel te geraken. Voor de één is Snowden een held, voor de ander een verrader. In dit boek trachten we een objectief beeld, zonder waardeoordelen, te geven. Wat wel buiten kijf staat is dat zowel Snowden als Assange de wereld getoond hebben dat er in de duistere wandelgangen van de veiligheidsdiensten zaken gebeuren waar “normale stervelingen” zelden weet van hebben.

Het waren vooral de onthullingen van Snowden die bij velen de oogkleppen deed afvallen. Op het Internet ben je hoegenaamd níét anoniem. Grote (en kleine) mogendheden en privéfirma’s kunnen ons doen en laten op het Internet bekijken, bewaren en analyseren. Privacy en het Internet zijn een *oxymoron*: een contradictorische term zoals zwarte sneeuw. Wanneer je je op het Internet begeeft, op welke manier ook, gooi je een deel van je privacy te grabbel. En dat is iets dat helaas de voorbije tien jaar er niet op verbeterd is (alhoewel het **Tor** netwerk met z’n *onion routing* toch wel een stevige extra privacy laag kan aanbieden).



Een interessant debat dat altijd opduikt bij deze problematiek is de “Ik heb toch niets te verbergen”-houding. In het kleine maar fijne boekje “Je hebt wél iets te verbergen” van onderzoeksjournalisten Maurits Martijn en Dimitri Tokmetzis (ISBN 9789082821611) wordt onherroepelijk brandhout gemaakt met deze stelling. Finaal zijn we volledig afhankelijk van de online diensten die we gebruiken en wat ze met onze data nu én belangrijker, in de toekomst zullen doen. Privé-informatie over jou die nu ogenschijnlijk ongevaarlijk lijkt, kan dat potentieel in de toekomst wel zijn wanneer normen, waarden of wetten veranderen.

2.1.4 2014: Hoe veilig is *the cloud* ?

In 2014 vond er een controversie plaats die vooral de puberende tiener zich zal herinneren: “*The fapping*”. Deze naam laat weinig aan de verbeelding over en dekt de lading goed. In het jaar dat Oekraïne Russische legers zag binnenrollen om de Krim (terug) in te palmen, verschenen er duizenden privéfoto’s van een honderdtal *celebrities* op het Internet. Deze, vaak weinig verhullende, privéfoto’s hadden kwaadwillige hackers van de Apple iCloud accounts van de slachtoffers gestolen en vervolgens gepubliceerd via Reddit, 4chan, etc. De foto’s verspreidden zich als een lopend vuurtje en de slachtoffers konden enkel toezien hoe hun in de privésfeer opgenomen beelden door miljoenen mensen werden gedownload.

De beroemdheden hadden hun foto’s in de cloud-opslag van Apple bewaard zoals op dat moment

duizenden gebruikers ook al deden. Deze dienst zorgt ervoor dat je je als eindgebruiker van eender waar aan je foto's kan, daar ze "in the cloud" staan, wat door de spectaculaire groei van de smartphones (en iPhones in dit geval) een populair concept was geworden. Ook diensten zoals Dropbox, Onedrive (toen nog SkyDrive) toonden aan dat er een grote vraag was naar online opslag van (privé-)informatie.

Om dergelijke diensten te gebruiken dien je natuurlijk een veilig wachtwoord te hebben, daar eender wie, van eender waar, kan proberen zich een weg naar je data te verkrijgen door jouw wachtwoord te raden. In 2014 waren concepten zoals 2-factor-authentication (2FA) en biometrische beveiliging (meer daarover in hoofdstuk 5) nog niet zo populair en dus was je geheime wachtwoord je enige bescherming tegen onrechtmatige toegang tot je data.

De diefstal van de foto's werd echter vergemakkelijkt door twee redenen:

- Sommige slachtoffers gebruikten makkelijk te raden, of snel te bruteforcen wachtwoorden.
- Anderen hadden de beveiligingsvragen ter goeder trouw ingediend. Veel diensten stellen een extra beveiligingsvraag (zoals "Wat is de naam van je eerste huisdier?" of "Op welke school zat je vader?") die ze kunnen gebruiken om jouw identiteit te verifiëren indien je je eigen wachtwoord vergeten bent en je dit wenst te resetten. Wanneer jij of ik dit soort vragen invullen dan is dit 90% van de tijd informatie die nergens te vinden valt, enkel in de grijze massa in je hoofd en misschien in een gënant dagboekje uit je jeugd. Bij de Amerikaanse beroemdheden wiens iCloud werd gehackt, is dat niet zo. Hun leven kan volledig gereconstrueerd worden aan de hand van de ontelbare interviews die ze al hebben gegeven. Gegarandeerd dat ooit een interviewer al heeft gevraagd wat de kleur van zijn of haar eerste auto was, of in welk dorp hij of zij is opgegroeid.



Het is een verkeerde reflex om in dit soort zaken ogenblikkelijk aan *victim shaming* te doen (kijk maar naar het recentere voorval waarbij enkele Bekende Vlamingen het slachtoffer waren van catfishing). Ieder doet en laat wat hij wenst in z'n privésfeer - daarom heet het ook privé - maar het is belangrijk te beseffen dat als je zaken *in the cloud* bewaard, de kans bestaande is dat iets of iemand er ooit onrechtmatige toegang tot zal krijgen. U weze gewaarschuwd.



Niemand verplicht je om op de beveiligingsvragen een eerlijk antwoord te geven. Er bestaat geen leugendetector in die systemen of een mama die op je vingers komt tikken. Lieg er dus op los, maar onthoud uiteraard je antwoord. Dankzij die beveiligingsvragen hou je echter een stok achter de hand moest je je wachtwoord vergeten zijn.

2.1.5 Ook in 2014: als landen vechten

Het was te verwachten dat ook op cyberniveau er ooit een cyber-wapenwedloop zou starten zoals, helaas, ook in de echte wereld plaatsvindt. Daar waar landen voorheen nog vooral defensieve cyber-mogelijkheden hadden, begon halverwege het vorige decennium dit arsenaal meer en meer uitgebreid te worden met offensieve cyberwapens. Het was met andere woorden wachten op de eerste cyberaanvallen door een soevereine staat op een andere staat.

Het probleem met cyberaanvallen is dat het als aangevallen mogendheid ongelooflijk moeilijk is om juist te reageren:

1. De bron van de aanval identificeren is soms onmogelijk. Wie weet lijkt de aanval te komen vanuit land X, terwijl het eigenlijk land Y is dat gewoon de aanval via land X routeert. En het laatste dat je natuurlijk wil doen is het verkeerde land beschuldigen (of aanvallen).
2. Wat als een hacker, zonder staatsinmengingen, beslist om op eigen houtje een cyberaanval te initiëren. Is het land van herkomst van die aanvaller dan verantwoordelijk voor de geleden schade?
3. De “schade” van een cyberaanval is niet altijd duidelijk. Wanneer een raket op een stad wordt afgestuurd is dat een duidelijk *act of aggression* en is er grote kans op een militair conflict (indien de diplomatieke weg geen soelaas brengt). Maar is een cyberaanval, zoals een denial-of-service (DoS, zie later), genoeg reden om de oorlog buiten het cyberdomein te escaleren? Zijn er eigenlijk *rules of engagement*? Is er een conventie van Genève? Neen op dit alles. Daar cyberaanvallen zo moeilijk te traceren en identificeren zijn, blijft het allemaal het betere nattevingerwerk.

Een bewuste cyberaanval op een soevereine staat is al een enkele keren gebeurd (denk maar aan de cyberaanvallen in 2007 van Rusland op Estland) maar in 2014 was er helaas een nieuwe primeur (Stuxnet krijgt eigenlijk die primeur, maar dat werd pas veel later bevestigd). Ook nu gaan we naar Hollywood, niet om de beroemdheden en hun privé-kiekjes, maar omwille van een film waar een andere staat niet om kon lachen.

In 2014 zou Sony een nieuwe film uitbrengen, getiteld “The Interview”, met James Franco en Seth Rogen. In deze komedie worden twee journalisten gevraagd om tijdens hun interview van een *fictieve* Noord-Koreaanse dictator hem te doden. De vergelijkingen met de Noord-Koreaanse leider Kim Jong-un waren voor iedereen duidelijk. Dat Noord-Korea op de tenen zou zijn getrapt, stond dan ook in de sterren geschreven.

De daaropvolgende gebeurtenissen zijn nog steeds niet uitgeklaard, maar vast staat wel dat een selecte groep hackers toegang had gekregen tot confidentiële data op de servers van Sony en deze vervolgens op het Internet lekte. De financiële schade voor Sony was enorm. De daders wisten onuitgebrachte films, e-mails, salarissen en andere privé-informatie te stelen. Heel lang werd gedacht dat de groeperingen die achter de aanval stonden door Noord-Korea waren aangestuurd. Echter, tot op de dag van vandaag

heeft men dat niet kunnen bevestigen. Zo zijn er ook experts die denken in het bewijsmateriaal de hand van Rusland en/of China te zien. Kortom, zoals eerder gezegd, cyberaanvallen zijn verdomd lastig om in kaart te brengen.

Als het toch Noord-Korea zou zijn geweest - wat nog steeds meer dan mogelijk is - dan hebben ze hiermee dus een dubieuze primeur: een soeverein land voert een cyberaanval uit op een bedrijf in een ander land. En de vraag die vervolgens veel experts zich stelden was: “Vanaf wanneer is dit een *act of aggression*?”, en ook: “Moet een land op dit soort aanval reageren namens het bedrijf, of namens de hele natie waar het bedrijf zich bevindt?” Wie zal het zeggen. Dit boekje helaas niet, maar het geeft wel voer voor discussie.

2.1.6 2015: Stuxnet bewaarheid

Keer op keer zullen we dit moeten herhalen: we kunnen nooit met 100% zekerheid de origine van een cyberaanval vaststellen. Heel af en toe, met dank aan klokkenluiders zoals Snowden, of verregaand (al dan niet journalistiek) onderzoek worden specifiek aanvallen volledig uit de doeken gedaan (maar helaas vaak jaren na datum).

In 2015, iets meer dan een jaar na de Sony aanval, werd dat waar we voor vreesden bewaarheid: hackers waren er in geslaagd om de elektriciteitsinfrastructuur van Oekraïne deels plat te leggen op 23 december, vlak voor kerstavond. Een groepering slaagde er zo in om bijna een kwart miljoen mensen gedurende meerdere uren zonder stroom te zetten. Iedereen keek uiteraard ogenblikkelijk in de richting van Rusland - Oekraïne maakte vroeger deel uit van de voormalige Sovjetrepubliek - daar de aanvallen kwamen van IP-adressen die waren toegewezen aan Rusland. Maar zelfs als dat zou zijn, zonder harde bewijzen dat de hackers ook handelden in naam van de Russische overheid blijft het koffiedik kijken wie *op de vingers getikt* moet worden voor de aanval.

Wie het ook waren, één ding staat wel vast: in 2015 waren hackers er voor het eerst in geslaagd om met één welgemikte aanval honderdduizenden mensen in problemen te brengen, problemen die verder gingen dan het verwijderen van enkele bestanden.

Enkele jaren later, in februari 2021, zou het trouwens weer bijna prijs zijn. Een hacker kreeg toegang tot de systemen die de waterzuiveringsinstallaties van Oldsmar (Florida, VS) bediende. Een operator zag op tijd dat z'n muis plots bewoog en de maximum toegelaten hoeveelheid natriumhydroxide waarde van de filters op een dodelijk niveau zette. Er werd gelukkig tijdig ingegrepen (en detectoren verderop in het systeem hadden het vergiftigde water sowieso gedetecteerd), maar het deed wederom de vraag rijzen of onze kritische systemen wel voldoende beveiligd zijn tegen dit soort *lone wolves*.

2.1.7 2015: Scheidingen en zelfmoord

In 2015 wordt de schaal van cyberaanvallen steeds groter. De hoeveelheden informatie die hackers van bedrijven kunnen bemachtigen kunnen al lang niet meer op één A4'tje afgedrukt worden. Wanneer hackers toegang krijgen tot de privé-servers van hun doelwit kunnen ze vlotjes ettelijke gigabytes, tot zelfs terabytes, aan privé informatie stelen. Tegenwoordig hebben we in Europa de GDPR wetgeving die probeert bedrijven duidelijk te maken dat zij verantwoordelijk zijn om onze data op een veilige manier te bewaren en hen ook te straffen indien ze dit niet doen. In 2015 was dat veel minder. De datalekken in die tijd spraken boekdelen: van zodra cybercriminelen toegang hadden tot de privéservers konden ze de data zonder problemen lezen. Paswoorden, kredietkaartgegevens, rijksregisternummers, alles stond vaak onbeveiligd (*ongeëncrypteerd*) op de systemen.

De Ashley Madison website was Tinder voor mensen die een relatie wilden naast hun “officiële relatie”. Kortom, de site hielp mensen aan een affaire. Hun leuze, *“Life is short. Have an affair”*, wond er geen doekjes rond. En met hun meer dan 20 miljoen “klanten” was het duidelijk dat ze een lucratief idee hadden. Dat ze tegenwind zouden krijgen was te verwachten...

In juli 2015 plaatste een groep hackers een ultimatum op een website aan het adres van de eigenaars van Ashley Madison: *“Haal jullie moreel dubieuze website van het Internet, of wij plaatsen meer dan 60 gigabyte aan gestolen data online”*. De site werd niet offline gehaald en de hackers “hielden woord.” De gevolgen waren immens, niet zo zeer voor Ashley Madison zelf, wel voor de klanten. Plotsklaps kreeg de wereld een lijst te zien waarin honderdduizenden klanten open en bloot aan de schandpaal werden genageld. Mensen werden publiekelijk vernederd. Er is sprake van minstens twee zelfmoorden rechtstreeks als gevolg van het lek. Mensen werden ontslagen. Kortom, het lekken van wat uiteindelijk maar een hoop binaire data was, had gevolgen op relaties, mensenlevens en carrières.

Als positieve noot in dit verhaal halen we hier uit dat dit soort gigantische lekken mensen heeft doen inzien dat ze tweemaal moeten nadenken voor ze hun persoonlijke informatie weggeven aan één of andere Internet-gigant (het is helaas een les die we jaarlijks lijken te vergeten, kijk maar naar de populariteit van Tik Tok, Facebook, etc.).



Een stelregel die bedrijven nu hanteren is de volgende: vraag je niet af **of** je gaat gehackt worden maar vraag je af **wanneer** je zal gehackt worden. Dit is een heel andere manier van tegen je beveiligingsprobleem aankijken. Vergelijk het met het in huis halen van een koffer met daarin 10 miljoen euro aan diamanten. Als je je afvraagt of er ooit inbrekers zullen binnen geraken en daar naar beveiligt - waakhonden, videocamera's rond het huis, dubbel slot - dan heb je daar niets aan als ze vervolgens toch binnen geraken en je koffertje stelen. Veel beter kan je én je huis beveiligen, én ervan uitgaan dat ze de koffer gaan bemachtigen: en je dus maar beter ook ervoor zorgt dat de dieven niets met de diamanten kunnen doen (door bijvoorbeeld je naam er in te graveren). Kortom: bedrijven moeten data die ze van ons opslaan minstens encrypteren en systemen inbouwen die de data onbruikbaar maken als ze toch gelekt zou worden.

2.1.8 2016: Internet-of-horrors

In onze huizen verschenen steeds meer apparaatjes die via het, meestal draadloze, netwerk met elkaar en het Internet konden communiceren. Internet-of-Things (IoT) bracht een weelde aan nieuwe oplossingen in onze levens. Domotica, wearables, slimme thermostaten, beveiligingsystemen, weegschalen, alles werd én slimmer gemaakt én aan het Internet gehangen.

Een inherent probleem met veel van deze, meestal kleine, toestellen is dat ze op het gebied van beveiliging ondermaats presteren. Dergelijke IoT-apparaten werken vaak op batterijen en de makers willen natuurlijk de batterijduur zo lang mogelijk houden. Iedere extra feature die de designers in het apparaat willen steken heeft een kost op die levensduur. Een aspect zoals beveiliging werd dan ook vaak achteraan de lijst van potentiële features geplaatst. Komt daarbij dat IoT-apparaten updaten (met bijvoorbeeld nieuwe security patches) soms onmogelijk of tenminste omslachtig is. Als er dus een beveiligingslek wordt gevonden in een apparaat, dan is de kans bestaande dat dit lek voor altijd aanwezig zal blijven én dus ook kan misbruikt worden.

Het was dus wachten tot de eerste aanvallen, specifiek gericht op IoT-apparaten, zouden plaatsvinden. De meest opvallende aanval gebeurde eind 2016. Malware, genaamd Mirai, verspreide zich als een lopend vuurtje over IoT-apparaten waarvan de malware het standaard wachtwoord en username kende. Gebruikers die vergeten waren het wachtwoord aan te passen, dat het apparaat heeft wanneer je het uit de doos, haalde zaten zo plotseling met een ogenschijnlijk perfect werkend, maar besmet apparaat. Echter, de malware nestelde zich onzichtbaar op het apparaat en wachtte op commando's van de Mirai makers. De malware creëerde met andere woorden een zogenaamde *botnet*, een groot netwerk van besmette apparaten die allemaal commando's kunnen uitvoeren van de *botnet herder* (i.e. degene die de malware in de eerste plaats is beginnen verspreiden). De Mirai-makers hadden zo een leger minicomputers onder hun bevel die ze konden zeggen "surf nu allemaal naar die website".

Een website die plots tienduizenden gebruikers onverwacht extra te verwerken krijgt zal vaak onder de druk bezwijken en crashen. Kortom, dit Mirai botnet kon zo grote distributed denial-of-service (DDOS) aanvallen uitvoeren, allemaal omdat gebruikers de wachtwoorden van hun gloednieuwe apparaatjes niet hadden aangepast. In hun verdediging, het is vaak een erg omslachtig, technisch, proces om het wachtwoord van een IoT-apparaat aan te passen.



De wildgroei van Internet-of-Things apparaten heeft ervoor gezorgd dat hackers een grote hoeveelheid extra mogelijkheden hebben bijgekregen om op huis en bedrijfsnetwerken te infiltreren. Of om het in hacker-termen te zeggen: dankzij de weelde aan IoT-apparaten is de *attack surface* voor aanvallers exponentieel vergroot.



Een dubieuze (deels betalende) site, **shodan.io**, heeft als enige doel alle Internet-of-Things apparaten in kaart te brengen die zichtbaar zijn vanop het Internet. Deze “Google voor IoT” toont zelfs om wat voor apparaten het gaat en welke bijvoorbeeld nog steeds het standaard (default) wachtwoord hebben.

2.1.9 2017: Ransomware wordt gemeengoed

De virussen in de vorige eeuw durfden al eens je data te verwijderen. Lastig, maar erg duidelijk: je data was je kwijt, tenzij je ergens een back-up had liggen. De nieuwe virussen gingen echter een stapje verder: ze versleutelden al je data (vaak ook je back-ups als je zo dom was geweest deze op het zelfde apparaat te hebben) én vroegen vervolgens losgeld in ruil voor je data. De naam *ransomware* kon, helaas, niet beter gekozen zijn. Menig particulier betaalde ogenblikkelijk om de eenvoudige reden dat de ransomware de gebruiker nog een uitweg aanbood daar ransomware vaak werd “binnengehaald” door een gênante actie (bv illegale software downloaden, op reclame voor vage pornosites klikken, etc.).

Voor particulieren was ransomware vooralsnog irritant. Maar wat als de ransomware bedrijfskritische data begon te encrypteren? Dit is exact wat er gebeurde in 2017 met de WannaCry en Petya ransomwares. Deze malwares sloegen er in om banken, hospitalen, havenbedrijven en menig ander groot (en klein) bedrijf te besmetten. De economische schade werd geschat op bijna 4 miljard dollar vanwege het lamleggen van de productie (of in het geval van enkele ziekenhuizen: het redden van mensenlevens).

De schade én de losgeldbedragen werden ook steeds groter. Zo was er het voorval met Garmin in de zomer van 2020 dat niet alleen de populaire sport-tracking diensten gedurende meerdere dagen uit de lucht haalde, maar er ook voor zorgde dat menig vliegtuig niet mocht vliegen omdat de Garmin Pilot

apps niet werkten waardoor de piloten geen up-to-date aeronautische plannen voorhanden hadden. Het is nooit geweten of Garmin het losgeld (10 miljoen dollar!) wel of niet heeft betaald, vast staat wel dat ransomware tegenwoordig een, helaas, erg lucratieve handel is geworden voor cybercriminelen.



In december 2022 was Digipolis, de IT-backbone van de stad Antwerpen, het slachtoffer van een zeer impacterende ransomware aanval door hackercollectief Play (een soort spin-off van Conti, een Russische hackersgroep). Quasi alle online-diensten van de stad Antwerpen zijn meerdere dagen onklaar gemaakt, inclusief politie, brandweer, bibliotheken, zwembaden, stadsloketten, stedelijke scholen, etc. Quasi iedere burger heeft in meer of mindere mate last ondervonden van deze gigantische aanval. Het toont vooral ook weer aan hoe gevoelig ons digitale leven is en dat er altijd een keerzijde is de digitalisering.

2.2 2020: De macht van sociale media

2016 ging er een schokgolf doorheen de wereld. Tegen alle verwachtingen in won Donald J. Trump de presidentsverkiezingen na een bitsige strijd tegen Hillary Clinton. Dat social media een belangrijke rol zouden spelen dit decennium was al lang voorspeld. Facebook, Twitter, Google en konsoorten hadden miljarden gebruikers die met plezier hun privacy te grabbel gooiden in ruil voor dagelijkse dopamine-shots dankzij *likes* en *retweets*. Met dank aan gigantische *troll farms* (organisaties die duizenden fake social media accounts aanmaken en zo mee de social media algoritmes beïnvloeden om bepaalde informatie te *nudgen* in de gewenste politieke richting) kon Trump honderdduizenden potentiële twijfelaars doen inzien dat hij het juiste antwoord was tijdens de verkiezingen.

De inmenging van Rusland in een buitenlandse verkiezing (een daad waar menig land zich reeds schuldig aan heeft gemaakt) was ontluisterend vanwege de schaal waarop het gebeurde. Het toonde de almacht van de grote Silicon Valley bedrijven en hoe zij op geopolitiek niveau een belangrijke speler zijn geworden. Iets dat vervolgens nogmaals bevestigd werd door het simultaan plaatsgevonden Cambridge Analytica schandaal, dat niet alleen mede ervoor gezorgd heeft dat Trump president werd, maar dat hoogstwaarschijnlijk ook een grote groep twijfelaars heeft kunnen overhalen om een pro-Brexit stem uit te brengen.

Drie jaar later zagen onderzoekers een soortgelijk fenomeen tijdens de verkiezingen van de Europese Unie in 2019. Een rapport toonde aan dat Rusland actieve misinformatie campagnes organiseerde om zo de verkiezingen te beïnvloeden. Ze gebruiken hierbij zogenaamde *bad actors*: fake social media accounts die (al dan niet fake) nieuws verspreiden dat “in de winkel van Rusland past”. Uit het onderzoek bleek dat de toenmalige belangrijkste EU-mandatarissen (Juncker, King, Tajani, etc.) soms tot 20% volgers op Twitter hadden die eigenlijk *bad actors* waren.



Wat is het nut van *bad actors* die bekende mandatarissen volgen? Deze trolls posten hun “anti-boodschappen” als reacties op posts van diegene dat ze volgden. Vervolgens zorgden ze ervoor (via bijvoorbeeld likes en retweets door mede trolls) dat hun boodschap bovenaan de lijst van reacties kwam. Hierdoor kreeg iedereen die de mandataris volgde vaak ook de troll-reactie(s) ogenblikkelijk te zien.

De voorbije jaren is er een (lichte) kentering bezig inzake de macht van de social media bedrijven, maar het blijft een feit dat momenteel wij allen grotendeels afhankelijk zijn van door artificiële intelligentie aangedreven algoritmes die bepalen welke informatie wij willen/zouden/moeten consumeren, ieder uur van de dag. Zolang echter data het nieuwe goud is en bedrijven dit vrij kunnen bewaren (GDPR poogt dit in te perken) zullen zij hun algoritmes kunnen blijven voeden en trainen om nog griezeliger/knapper te maken.

Het gevolg van die *datahoarding* is echter ook dat datalekken ook steeds nefastere gevolgen hebben. Daar waar het bij Ashley Madison nog ging om een dikke 20 miljoen user accounts, medio 2021 zijn het aantal accounts dat bij een datalek betrokken zijn soms vertienvoudigd - de MGM Grand Hotels keten zag in de zomer van 2020 plots 142 miljoen van z'n gast-accounts te koop staan voor een schamele 3000 dollar in bitcoin.



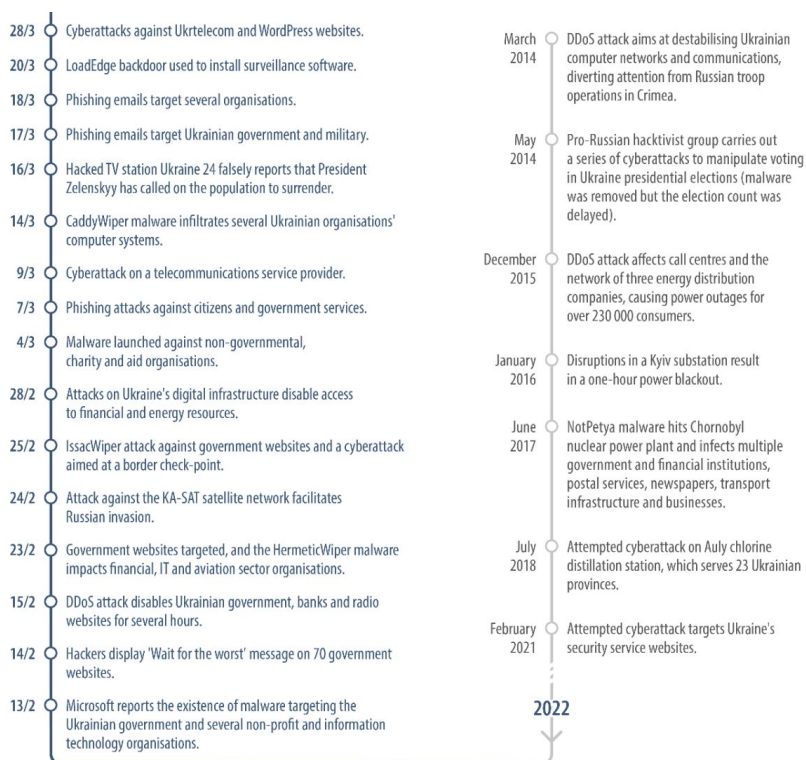
Twee boeken, die lezen als rasechte thrillers, gaan dieper in op de zonet beschreven gebeurtenissen: “Sandworm - A New Era of Cyberwar and the Hunt for the Kremlin’s Most Dangerous Hackers” van Andy Greenberg en “How they tell me the world ends” van Nicole Perlroth..

2.3 2022: Oorlog en AI

Een glazen bol hebben we niet, maar vast staat dat het er niet op zal verbeteren. Zoals gezegd gaan bedrijven uit van *when* in plaats van *if* als het gaat over de vraag of ze al dan niet ooit gehackt zullen worden. Daarnaast zien we dat hoogtechnologische producten meer en meer ingeburgerd geraken in het cybercrime-milieu. Deep fakes video van bekenden zijn nu nog “grappig”, maar de realistische beelden (afbeeldingen, video én nu zelfs ook spraak) die ze kunnen produceren zijn al even niet meer te onderscheiden van het echte en zullen dus meer en meer kunnen gebruikt worden voor sextortion en soortgelijke schandalen. Dit soort trends zullen nog jaren *fake news* hoogtij laten vieren waardoor ook toekomstige verkiezingen interessante doelen blijven voor andere mogelijkheden om hun stempel te drukken op geopolitieke tegenstanders.



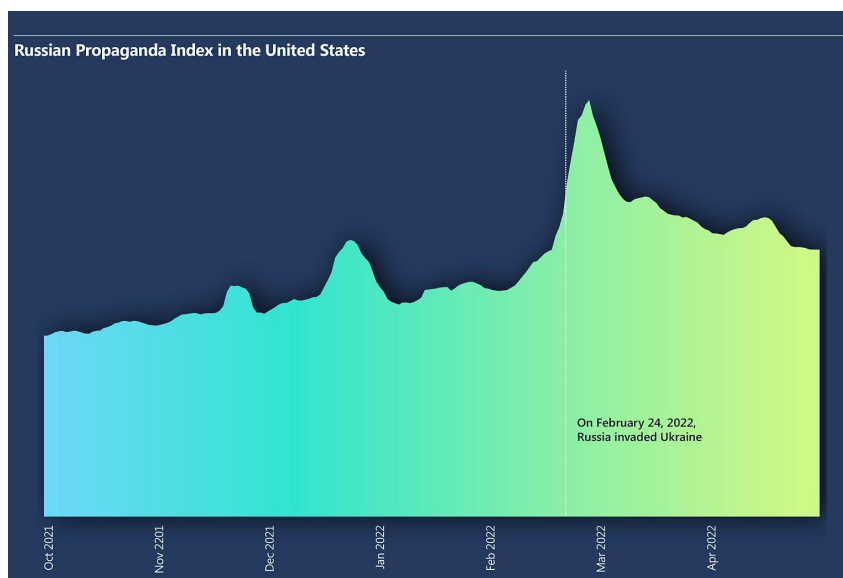
Sinds de oorlog in Oekraïne is uitgebroken zien we ook terug verregaande cyberactiviteit vanuit Rusland. De eerste weken van de oorlog (februari 2022) was het opvallend stil en leek het alsof *de angst voor Russische cyberoorlog* ongegrond was. Ondertussen zijn we helaas meer dan een jaar verder en verschijnen er meer en meer verhalen, zoals verwacht, van Russische cyber-inmenging. [Volgende artikel geeft een heldere tijdslijn hiervan.](#)



Figuur 2.3: Een stuk van de zonet beschreven tijdslijn uit het door het Europese parlement gepubliceerde rapport.



Microsoft monitort al geruime tijd de vele fake news bronnen die Rusland rijk is. Er wordt zelfs een **Russian Propaganda Index** (RPI) bijgehouden die aangeeft hoe actief de Russische trolls momenteel zijn in het verspreiden van bewezen onwaarheden (o.a. over de oorlog in Oekraïne, binnenlands beleid van andere mogendheden, COVID-19 vaccins, etc.)



Figuur 2.4: Zoals verwacht zag de RPI-grafiek een stevige stijging aan de start van de illegitieme invasie van Oekraïne door Rusland. Bron: <https://www.microsoft.com/en-us/security/business/microsoft-digital-defense-report-2022-cyber-influence-operations>.

Om nog maar te zwijgen over de opkomst van ongelooflijk krachtige AI systemen. Sinds de winter van 2022 worden we constant overspoeld met nieuwe AI toepassingen die zo krachtig zijn dat er zelfs in maart 2023 werd voorgesteld om alle AI onderzoek “even te pauzeren”, zodat wij, als gemeenschap, kunnen reflecteren (én bijbenen) over hoe we onze toekomst met AI willen opbouwen. Onze glazen bol is niet perfect, maar wees er maar van overtuigd dat we de komende jaren onvoorspelbaar, bizarre, krachtige cyberaanvallen gaan tegenkomen die door AI worden ondersteund. Een eerste voorbeeld hiervan zagen we reeds recent in de zomer van 2023 genaamd **DarkBert**, een broertje van ChatGPT dat was getraind op DarkWeb data en dus de ideale chatpartner is voor conversaties die het daglicht niet mogen zien.

2.4 Het is erger, maar...

Dus ja, het wordt helaas erger. De wapenwedloop in de cyberwereld gaat beangstigend snel vooruit en het wordt moeilijker en moeilijker om als “normale sterveling” er een antwoord op te geven. Als een IoT botnet van 10 miljoen apparaten morgen beslist om de infrastructuur van jouw KMO plat te leggen, dan zullen ze daar in slagen, ongeacht de vele euro’s die je hebt geïnvesteerd in firewalls, intrusion detection systems, virusscanners en honeypots.

Aan de andere kant heeft de wapenwedloop er wel voor gezorgd dat onze infrastructuur ook steeds complexere aanvallen kan weerstaan. Hierdoor wordt het voor huis-tuin-en-keuken malware een pak moeilijker om nog computers van thuisgebruikers te besmetten.

Maar laten we deze cyberstropers geen vrij spel geven! Laten we leren van hun technieken om zo zelf onze systemen en personeel te *hardenen* en te beschermen tegen wat niet anders dan het “wilde westen van het Internet” (dixit komiek Steven Wright) kan genoemd worden.

3 Cybersecurity fundamenteën

“Iedere goede film begint met een zwart scherm”, zegt Batman in de “The Lego Batman Movie”™ film. Wel, ik vul dit aan met “...en ieder goed hoofdstuk begint met een definitie.”

Laten we daarom eerst eens een definitie van cybersecurity neerpennen dat netwerkbedrijf *Cisco* gebruikt:

“Cybersecurity is the practice of protecting systems, networks, and programs from digital attacks. These cyberattacks are usually aimed at accessing, changing, or destroying sensitive information; extorting money from users; or interrupting normal business processes.

Implementing effective cybersecurity measures is particularly challenging today because there are more devices than people, and attackers are becoming more innovative.”

Alles draait met andere woorden rond het beschermen van informatie, of dat die nu op een server, in een document of in iemands hoofd zit.

3.1 CIA en het security model

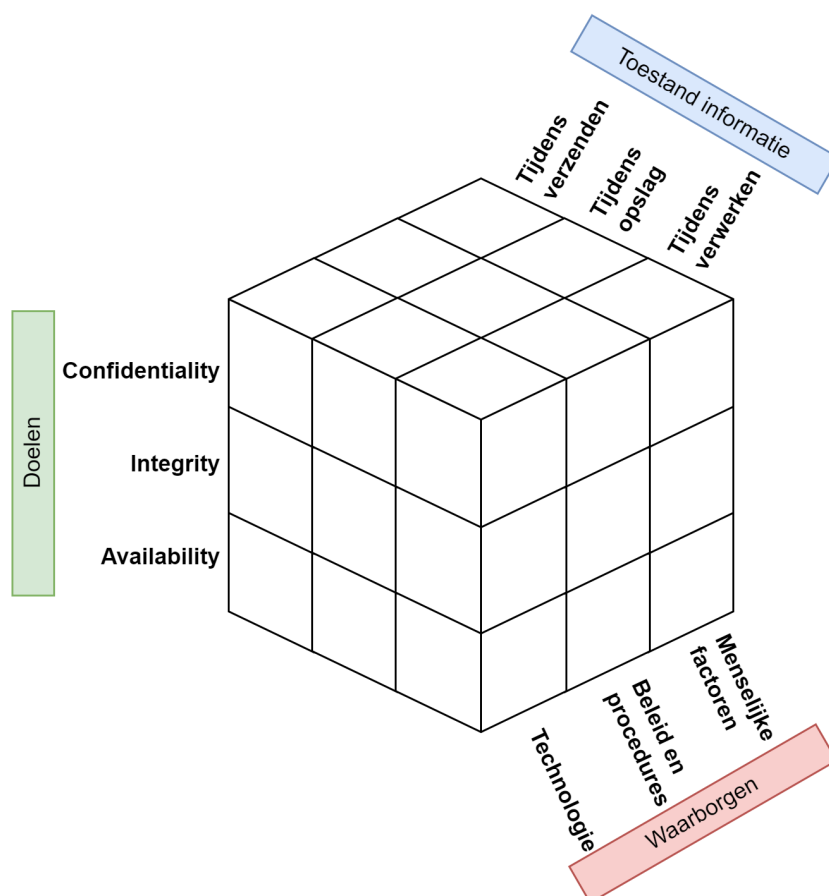
Data (of informatie), in welke vorm dan ook (berichten over een netwerk, bestanden op een harde schijf, tekst in een database), moeten beschermd worden, dat beseffen we nu. Het doel van onze data is dat deze voldoet aan het acroniem **C.I.A** wat staat voor:

- **C** voor “**confidentiality**”: vertrouwelijkheid. De data kan enkel door zij die er recht toe hebben gebruikt worden. We gaan dit onder andere oplossen met behulp van encryptie en wachtwoorden.
- **I** voor “**integrity**”: integriteit. We moeten weten of onze data onbeschadigd is en niet werd aangepast door derden (of storingen). Bij bestanden gaan we bijvoorbeeld werken met zogenaamde (secure) hashes.
- **A** voor “**availability**”: beschikbaarheid. Data die niet door rechtmatige gebruikers kan bereikt worden is onbestaande data. Zogenaamde “Denial-of-Service” (DoS) aanvallen hebben als doel deze pijler van CIA aan te vallen. Availability is een breed veld en wordt onder andere opgelost door back-ups, redundante servers enerzijds, en preventieve maatregelen anderzijds zoals firewalls, load balancers, etc.

3.1.1 McCumber kubus

De zogenaamde McCumber kubus, ontwikkeld door John McCumber in 1991, geeft een goed beeld weer waarom het steeds belangrijk is goed te beseffen binnen welke context we praten. Deze kubus stelt een model voor dat kan gebruikt worden om je ervan te vergewissen dat je aan alles denkt wanneer je je informatie wilt beschermen. De kubus bestaat uit drie dimensies en iedere dimensie bestaat uit een aantal aspecten. **Enkel wanneer we alle aspecten van alle dimensies in onze beveiligingsaanpak voorzien kunnen we hopen dat we onze C.I.A. doelen hebben bereikt.**

Om ons doel te bereiken (C.I.A.) moeten we ervoor zorgen dat we dit toepassen op alle vormen die onze data kan hebben (opslag, verzenden, verwerken). Dit kunnen we bewerkstelligen door technologische oplossingen (zoals encryptie wat in het volgende hoofdstuk wordt uitgespit), maar een niet onbelangrijke factor zijn ook de mensen die met de data moeten werken. Als zij zich niet aan de afspraken (procedures) houden en hun wachtwoorden gewoon op post-its aan hun scherm hangen, dan mag je een nog zo'n dure firewall hebben, het zal niet baten.



Figuur 3.1: De McCumber kubus.



De wereld van de cyberboswachters houdt van afkortingen, protocollen en vreemd klinkende standaarden. De wereldwijd gebruikte **ISO 27001** standaard (of norm) is er zo eentje, maar wel een erg belangrijke om te kennen. Wanneer een bedrijf of organisatie wil aantonen dat ze informatiebeveiliging hoog in het vaandel dragen, dan zullen ze deze norm trachten te behalen. Om als *ISO 27001 bedrijf* door het leven te mogen gaan moeten ze aan een hele hoop strenge eisen voldoen (die alle dimensies van de McCumber kubus omvatten, zou je kunnen zeggen) die in de standaard beschreven staan. Hierbij zal een externe auditor vervolgens controleren of je hier aan voldoet als bedrijf (en moet je dit elke drie jaar opnieuw doen).

3.2 Een ongelijke strijd

De McCumber kubus is een mooi concept, maar het is ook niet meer dan dat: een theoretisch framework. Het is ideaal om vanuit een high-level perspectief je ervan te vergewissen dat je aan alles hebt gedacht, maar in de praktijk komt er uiteraard bij alle aspecten van deze kubus aardig wat kijken.

De cyberboswachters van de 21e eeuw hebben geen eenvoudige job. Ze was in de vorige eeuw al pittig, de laatste jaren is de wapenwedloop er helaas alleen maar grimmiger op geworden.

- De aanvallers kunnen aan bijna supersonische **snelheid** aanvallen op duizenden, of zelfs miljoenen, systemen starten.
- “Alles is verbonden”: onze huidige IT-netwerken zijn vele malen groter en complexer dan circa 20 jaar geleden. Hierdoor is ook de zogenaamde **attack surface** steeds groter. Gedaan zijn de tijden dat een middelgroot tot groot bedrijf genoeg had aan één cyberboswachter. Er zijn nu zelfs bedrijven die kunnen ingehuurd worden om bij problemen (of slimmer: vooraf als audit) te komen helpen om de boel te blussen.
- De tools die aanvallers, van welke aard ook, ter hun beschikking hebben zijn vaak ongelooflijk **eenvoudig** geworden. Gedaan is de tijd dat een ietwat stevige aanval kon gedaan worden door experts met tien jaar script- en netwerkervaring. Sommige vreeswekkende aanvallen vereisen niet meer dan het IP-adres van het slachtoffer in een invulveld invullen en vervolgens een klik op een grote rode knop “Start attack”.
- Aanvallers schuimen *underground* fora af, op zoek naar de nieuwste *zero-day vulnerabilities* die ze in hun arsenaal kunnen opnemen. Fabrikanten van besturingssystemen en software kunnen de **snelheid waarmee nieuwe zwakheden** in hun systeem worden gevonden niet volgen.
- Door voorgaande snelheid van nieuwe zwakheden, duurt het ook langer en langer voor alles kan **gepatcht** worden door de ontwikkelaars van de software.
- Aanvallers kunnen **gigantische legers van computers en botnets** gebruiken om een ijzingwek-

kende hoeveelheid aan simultane aanvallen op één enkel slachtoffer uit te voeren.

- **Gebruikers** zijn een nog kleiner radertje in dit alles geworden en zullen nog sneller fouten maken (klikken op een link in een phishing e-mail bijvoorbeeld) dan voorheen, met alle gevolgen van dien.

3.2.1 Zero days en patching

Aanvallers hebben voor zero days aardig wat geld over. Een zero day kopen is een aanval kopen die gegarandeerd zal werken daar deze een zwakte misbruikt die nog niet bij de maker van de software gekend is.

Een zero day zal quasi gegarandeerd blijven werken tot de ontwikkelaars een nieuwe patch ervoor maken. Maar zelfs dan blijven zero days nuttig: het is niet omdat er een patch bestaat, dat de doelwitten deze patch ook effectief reeds geïnstalleerd hebben. Veel bedrijven hebben nu erg strenge *patching policies* maar toch blijft het dweilen met de kraan open: er moet maar één systeem niet gepatcht zijn tegen de zero day van de aanvallers en het gaatje in de verdedigingslinie is gevonden en kan misbruikt worden.

De meeste fabrikanten van besturingssystemen (Apple, Microsoft, etc.) en veelgebruikte softwarepakketten (Adobe, Microsoft, etc.) brengen patches op welbepaalde dagen uit. Dit zorgt er bijvoorbeeld voor dat systeembeheerders hier rekening mee kunnen houden in hun wekelijkse planning. Voor gebruikers van zero days is dit ook nuttig: er ontstaat een zogenaamde **window of vulnerability**. Dit is de periode tussen het “ontdekken en in gebruik nemen van een zero day” en de moment waarop de patch tegen de zero day wordt verspreid. In dit *window* heeft de aanvaller vrij spel daar geen enkel systeem al kan gepatcht zijn.



In 2021 verscheen “How they tell me the world ends” van New York Times journaliste Nicole Perlroth. Dit boek is erg ontluisterend en geeft een griezelig inzicht in hoe het er momenteel aan toe gaat in de schimmige wereld van zero days, offensieve cybersecurity, etc. Bekijk bijvoorbeeld maar eens de twitter-account van Chaouki Bekrar (twitter.com/cbekrar), oprichter van Zerodium, een zero-days *broker* en huiver bij de gigantische prijzen die zero days waard kunnen zijn (soms meer dan één miljoen dollar...).

3.3 Wie zijn de stropers?

Waar moeten we ons tegen beschermen als cyberboswachter? Het zou verleidelijk zijn om ons te richten op één specifieke doelgroep en ons daar volledig tegen te wapenen. Helaas is het niet te

voorspellen van wie je last zal hebben. Iedere groep aanvallers heeft eigen motivaties en middelen en het is niet altijd evident om tegen ieder iets te doen. Het kan natuurlijk geen kwaad om tenminste te weten met welke groepen je mogelijk zal geconfronteerd worden:

- **Hackers:** waarbij we een onderscheid moeten maken tussen white, black en grey hat hackers uiteraard.
- **Scriptkiddies:** een groep die soms te laat beseft dat ook zij dingen doen die erg strafbaar zijn.
- **Werknemers:** een vaak over het hoofd gekeken, maar oh zo veel voorkomende groep.
- **Cybercriminelen:** dé grootste plaag, nog steeds.
- **Cyberterroristen:** rebel, vrijheidsstrijders, terrorist. *It's all in the eye of the beholder* uiteraard.
- **Spionnen** : *James Bond of the WWW*.
- **Overheden** (of door overheden gesponsord): een probleem dat steeds groter blijkt te worden.

3.3.1 Hackers

Wanneer een digitale stroper niet onder één van de andere noemers kan gezet worden dan wordt hij “hacker” genoemd, een soort catch-all term die soms een positieve, soms een negatieve connotatie heeft. Om toch wat onderscheid mogelijk te maken kunnen we zeggen dat er drie soorten hackers zijn:

- **Whitehat:** “de goei”. Dit zijn hackers die onder duidelijke afspraken met hun doelwit de sterktes en zwaktes van een systeem zullen testen door deze te proberen te omzeilen. White hat hackers werken volledig binnen de klijtlijnen van de wet en zullen enkel die zaken testen waartoe zij recht hebben. Denk bijvoorbeeld aan audit-bedrijven die de beveiliging van andere bedrijven zullen *pentesten* (penetration testing: trachten in een systeem te geraken) of bounty hunters die bijvoorbeeld via *integrity.com* op zoek gaan naar nieuwe problemen bij een website of product.
- **Greyhat:** letterlijk een grijze zone. Grey hat hackers hebben meestal een positief doel maar zullen niet altijd volgens “de regels van de wet werken”. Denk maar aan een hacker die ongevraagd een lek ontdekt in een bedrijf en dit ook rapporteert. De kans is bestaande (maar gelukkig kleiner dan vroeger) dat het bedrijf in kwestie hier niet mee opgezet is en alsnog de hacker zal aanklagen. Vergelijk grey hat hackers met een soort “goede dief”: hij gebruikt zijn expertise om ongevraagd huizen binnen te breken om dan vervolgens, zonder iets te stelen, een briefje achter te laten met uitleg hoe de inbreker net is binnen geraakt.
- **Blackhat:** de “bad guys” van de hoop en ook wel *crackers* genoemd. Black hat hackers zullen systemen aanvallen waar ze geen toestemming voor hebben en meestal met als doel om niet legale resultaten (lees: geld, kennis of macht) te bereiken ten koste van het doelwit.

Recent zijn er nog 3, minder vaak gebruikte, types die aan de hand van een kleur specifieke hacker-types definiëren:

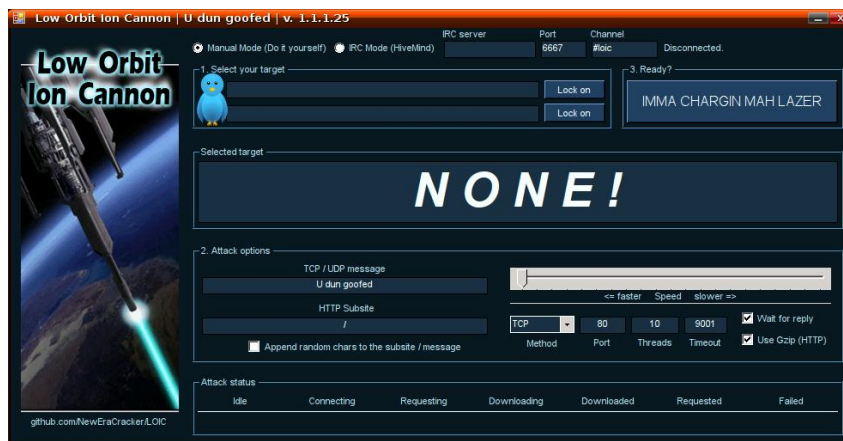
- **Redhat:** dit zijn hackers die als doel hebben blackhat hackers het leven moeilijk te maken. Ze worden ook soms *vigilantes* genoemd. De middelen die de redhat hackers gebruiken zijn echter niet noodzakelijk legaal en dus alhoewel hun doel nobel is, moeten we toch vraagtekens plaatsen bij hun werkwijzen.
- **Bluehat:** de wraaklustige hackers. Bluehat hackers hebben maar 1 doel, en dat is wraak nemen op iets of iemand, gebruik maken van alle middelen beschikbaar. Laten we auteur Jodi Picoult citeren die het volgende zegt over wraak: *“When you begin your journey of revenge, start by digging two graves: one for your enemy, and one for yourself”*...
- **Greenhat:** de jonkies, ook wel scriptkiddies genoemd. We zullen deze in de volgende sectie uit de doeken doen.

3.3.2 Scriptkiddies

Iemand die weinig tot niets kent van cybersecurity maar toch bestaande tools uittest op slachtoffers, wordt ook wel een scriptkiddie genoemd. Deze groep mensen gebruikt tools die eenvoudig in gebruik zijn, zonder altijd goed te weten wat de tool doet én wat de gevolgen ervan zijn. Doordat tools steeds krachtiger worden, zijn ook de gevolgen van scriptkiddie-aanvallen steeds drastischer. Wat deze gebruikers vaak vergeten is dat hun acties strafbaar zijn. Zo vergeten ze dat klikken op een knopje in een programma, vanuit hun gezellige bureaunkamer thuis, erge gevolgen kan hebben voor hun doelwit. Het gebeurt dan ook geregeld dat een scriptie onzacht én snel in aanraking met het gerecht komt. De veiligheidsdiensten die op cyberaanvallen reageren kunnen natuurlijk niet zien wie er achter een aanval zit en zullen dus altijd op dezelfde manier reageren. Een inval van een team zwaar bewapende agenten omdat een bank of webshop al dagen wordt lamgelegd is een “ervaring” die een scriptkiddie nog lang zal herinneren (en zien op z’n lege spaarboekje ten gevolge van de grote boetes die hij of zij nog jaren zal moeten afbetalen)



Low Orbit Ion Cannon is zo'n typische scriptkiddie tool: eenvoudig in gebruik, met potentieel grote gevolgen voor het slachtoffer. Deze tool, wanneer meerdere gebruikers hem samen gebruiken, voert DDOS-aanvallen op het doelwit uit. In 2010 werd de tool bijvoorbeeld gebruikt om de servers van Visa, MasterCard en Paypal uren lang lam te leggen als wraak op het feit dat deze betalingsdiensten geen betalingen voor WikiLeaks meer aanvaardden. [Meer informatie](#).



Figuur 3.2: Low Orbit Ion Cannon UI (Bron Wikipedia).

3.3.3 Werknemers

Werknemers die niet tevreden zijn over hun baas of werkomgeving, of net zijn ontslagen, zijn een veelvoorkomend probleem (volgens sommige experts zelfs hét belangrijkste cybersecurity probleem). Ze zitten vaak letterlijk “aan de binnenkant” van de beveiligingssystemen en kunnen daardoor ook veel meer schade aanrichten als ze dat willen. Ontevreden werknemers die wraak nemen op hun werkgever is een veel voorkomend probleem. Zeker als die werknemer op de koop toe bijvoorbeeld de netwerk-administrator was. Er zijn verhalen van ex-admins die voor hun vertrek de IT-systemen van het bedrijf saboteerden en, als klap op de vuurpijl, dan ook nog eens losgeld eisten om de systemen terug up-and-running te brengen. Het hoeft natuurlijk niet zo spectaculair zijn. Of wat te denken van werknemers die waardevolle documenten stelen, doorverkopen of aanpassen zonder dat het bedrijf er erg op heeft.

Werknemers zijn ook vaak onbedoeld de oorzaak van veel problemen: ze gaan misschien slordig om met de manier waarop ze hun wachtwoord bewaren, waardoor anderen via hun account kunnen inbreken. Ze laten mensen binnen die gekleed zijn als “collega’s” zonder te vragen of ze wel werknemer van het bedrijf zijn. Of ze installeren bijvoorbeeld een extra draadloos access point om een betere wifi-dekking op de bureau te hebben, waardoor dit toestel plots een veel minder goed beveiligd doelwit

is dat hackers kunnen misbruiken.



Veel van dit soort problemen kunnen voorkomen worden door een doordacht “identity management”-systeem dat er voor zorgt dat de accounts van recent ontslagen werknemers ogenblikkelijk worden verwijderd of dat tenminste de toegang tot bedrijfskritische systemen uitschakelt. Voorts moet personeel (op alle niveaus!) opgeleid en getraind worden zodat ook dit facet van de McCumber kubus gedekt wordt.

De laatste tien jaar heeft het **Bring your own device (BYOD)**-concept in bedrijven voor een extra dimensie gezorgd waar cyberboswachters rekening mee moeten houden. Vroeger kon je je verdediging opbouwen als een soort ommuurde burcht waarbij je er van uit mocht gaan dat alles “binnen de burcht” veilig was. Door BYOD gaat dit concept natuurlijk niet meer op: gebruikers wandelen bedrijven binnen met hun eigen laptop, tablet, smartwatch en smartphone, etc. Allemaal apparaten die potentieel door stropers vooraf, bij de gebruiker thuis, werden geïnfecteerd. Van zodra dit besmette apparaat dan in het bedrijf wordt geïntroduceerd heeft de aanvaller mogelijks ongelimiteerde toegang tot het bedrijfsnetwerk. Kortom, we moeten nu ook verdedigingsmuren rondom de individuele werknemers én hun apparaten bouwen. Denk daarbij aan on-device firewalls en virusscanners, maar ook netwerk-authenticatie voor ieder toestel, etc.

3.3.4 Cybercriminelen

Money talks zegt men wel eens, en dat geldt (geld, snap je'm ;)) zeker voor deze groep. Cybercriminelen doen wat criminelen al millennia doen en dat is rijkdom die hen niet toebehoort proberen te pakken krijgen. Geld, geld, geld is de motivatie van deze groep mensen. Een onderzoek in 2021 ([bron](#)) schat dat meer dan 700 miljard dollar verlies werd opgetekend ten gevolge van online criminaliteit. Doordat steeds meer mensen hun betalingen en identiteiten (denk maar aan de vele its-me phishing sms'jes dat je geregeld krijgt) online beheren wordt ook de groep potentiële slachtoffers steeds groter.

Cybercriminaliteit wordt soms wel eens de motor van de cybersecurity genoemd omdat ze steeds blijven innoveren en zoeken naar nog betere manieren om onschuldige slachtoffer hun centjes te stelen. Hierdoor moeten ook de boswachters steeds blijven vernieuwen.

Cybercriminaliteit is nu zelfs zo ver geëvolueerd dat ze heuse moderne bedrijfsconcepten overnemen en hun zaakje als echte bedrijven runnen. Moderne ransomware criminelen hebben zelfs helpdesks die je kan bellen om je te helpen om de betaling (de *ransom*) te regelen. Of wat te denken van website die botnets verhuren als waren het legale services. Hier en daar zie je nu zelfs het “-as a service” zinnetje verschijnen waarbij bijvoorbeeld “Ransomware as a Service” ([RaaS](#)) of “spam as a service”

kan gehoord worden. Het doel hierbij is natuurlijk om de strafbare feiten zoveel mogelijk te verleggen naar de persoon die de services inhuurt, en niet naar de aanbieder ervan.

3.3.5 Cyberterroristen, spionnen en overheden

De laatste drie groepen bespreken we samen, ook al omdat de termen soms overvloeien afhankelijk aan wie je vraagt om iets of iemand met dit label te bestempelen. Zoals reeds in het eerste hoofdstuk aangehaald is de cyberwereld tegenwoordig ook een belangrijk terrein waar geopolitieke ruzies op worden uitgevochten. Er bereiken ons steeds meer berichten van de exploten die hier doorgaan. De financiële en technische middelen die deze groep voorhanden heeft voor zowel offensieve als defensieve cyberacties is meestal immens groter dan van alle andere stropers in dit overzicht. We zagen ooit een presentatie waarin een cybersecurity expert ietwat lachend sprak over het “Mossad / Non-Mossad verdedigingsprincipe” (Mossad is een Israëlsche geheime dienst en staat in de top van *strafste* cybersecurity expertise). Het principe gaat uit van de manier waarop je je beveiliging opbouwt: ga er van uit dat de Mossad in je systemen zal geraken, ongeacht hoeveel geld en personeel je tegen het probleem aan gooit. Het is met andere woorden efficiënter dat je een realistische inschatting maakt van je tegenstanders (qua expertise en middelen) en daar specifiek je op richt, waarbij je natuurlijk het *low hanging fruit* niet over het hoofd ziet.

3.4 Hoe vallen ze aan?

Alhoewel voorgaande groepen van aanvallers allemaal erg specifieke redenen hebben, kunnen we toch hun aanvallen generaliseren in vijf duidelijke stappen:

1. **Verkennen:** passieve *reconnaissance*. Voor de stropers hun aanval effectief starten zullen ze eerst hun doelwit(ten) onderzoeken. Ze zoeken zo naar de eenvoudigste, of meest verborgen, manier om in een systeem te geraken. Verkennen wordt ook wel passieve reconnaissance genoemd omdat in deze fase het doelwit bijna nooit kan detecteren dat de stroper actief is. Deze fase gaat erg breed en is niet beperkt tot enkel “tools” gebruiken. In deze fase zal de stroper ook vaak via zoekmachines, social media en *dumpster diving* proberen meer te weten te komen over het bedrijf, de werknemers, etc.
2. **Scannen:** actieve *reconnaissance*. Van zodra de stroper een breed overzicht heeft van z’n doelwit zal hij overgaan op actieve scanning. Denk hierbij aan port scanners, vulnerability scanners, etc. Uiteraard is deze fase actief én bestaat er dus de kans dat de boswachters dit tijdig opmerken en zo de aanvallen in de volgende fase kunnen afslaan.
3. **Toegang verkrijgen:** door het scannen weet de stroper nu welk systeem hij zal benaderen om toegang tot bijvoorbeeld het bedrijfsnetwerk te krijgen. Meestal heeft de aanvaller een systeem

gedetecteerd in de vorige fase met een gekende kwetsbaarheid, of hij heeft bijvoorbeeld via spear phishing een backdoor bij een werknemer geïnstalleerd, etc. In deze fase zal de aanvaller ook trachten steeds meer rechten te krijgen zodat hij steeds meer kan gedaan krijgen op de *gepwnde* systemen.

4. **Toegang bestendigen:** van zodra de stroper *in het systeem* zit, begint hij als eerste z'n toegang te bestendigen. De aanvaller kan niet voorspellen wanneer het systeem waar hij op zit wordt uitgeschakeld, verwijderd, etc. Kortom, de stroper begint nu naarstig z'n toegang te garanderen door bijvoorbeeld een (nieuwe) backdoor te installeren die ook later actief zal zijn. Voorts zal hij ook mogelijk andere systemen in de buurt aanvallen zodat hij niet beperkt is tot één systeem (en er dus ook geen “*single point of failure*” is voor de stroper).
5. **Sporen wissen:** hoe langer de stroper uit het vizier van de boswachters kan blijven, hoe effectiever hij z'n doelen kan behalen. Een behendig stroper zal er dan ook voor zorgen dat zijn sporen ondetecteerbaar blijven door het aanpassen of wissen van logs, het verwijderen van backdoors, etc.

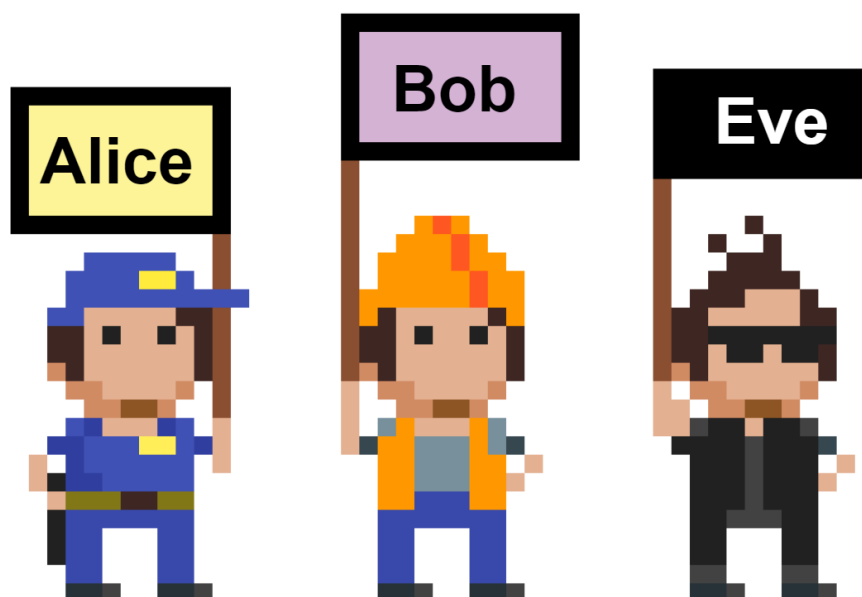


Wanneer een netwerk wordt gepentest (legaal) werkt men vaak met twee teams die tegen elkaar strijden. Het *red team* speelt de rol van de digitale stropers, terwijl het *blue team* als boswachters zal proberen de aanvallen te verijdelen.

3.5 Classificatie van aanvallen

Dit hoofdstuk begon met een definitie, dan moeten we zeker ook eens enkele zaken classificeren. Alles (moet gedaan worden) om ietwat wetenschappelijk over te komen, niet waar. In dit geval gaan we eens kijken hoe we, algemeen gezien, de typische aanvallen kunnen classificeren die kunnen optreden in de cyber security wereld. Specifiek zullen we met drie personages werken:

- Alice en Bob: zij zijn de *goeie* en willen op een veilige manier met elkaar communiceren.
- Eve: zij is de aanvaller/hacker/crimelord/snoodaard die het leven van Alice en Bob zuur wil maken in haar voordeel. Mogelijk wil ze te weten komen wat Alice en Bob met elkaar afspreken, misschien wil ze ervoor zorgen dat de berichten van Alice niet bij Bob aankomen, etc.



Figuur 3.3: Meet the crew.



Herinner je even aan de McCumber kubus: Alice en Bob zijn eender welk start- en eindpunt van onze informatie, in welke vorm dan ook. Als je bijvoorbeeld C.I.A. vereist in een computer dan is Alice bijvoorbeeld je CPU en Bob het RAM-geheugen (om maar iets te zeggen). Kortom, probeer altijd al deze informatie breed genoeg te plaatsen en niet alleen aan het klassieke “netwerkcommunicatie”-systeem te denken waarin Alice over een netwerk een boodschap naar Bob stuurt.

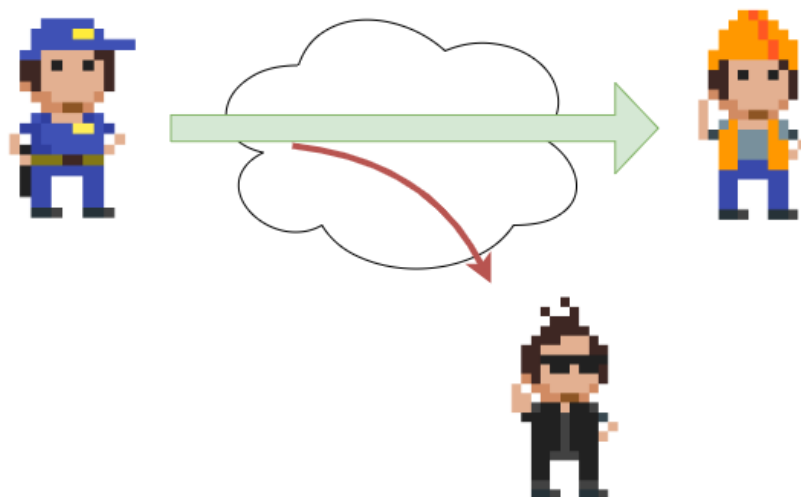
Eve kan op allerlei manieren *aanvallen* en in de eerste plaats kan dat **actief** of **passief** zijn: bij passieve aanvallen zal Eve enkel *luisteren* (en wachten) op de communicatie tussen Alice en Bob. Hierdoor zijn passieve aanvallen veel moeilijker om te detecteren (soms zelfs onmogelijk), maar uiteraard is Eve 100% afhankelijk van wat Bob en Alice doen, daar ze geen dwingende hand heeft in hun communicatie. Bij actieve aanvallen is dat omgekeerd: de pakkans is groter (en afhankelijk van het type aanval), maar ze kan ook mogelijk de communicatie tussen Bob en Alice sturen in de richting die zij nodig heeft om haar aanval uit te voeren.



Figuur 3.4: Passieve vs actieve aanvallen.

3.5.1 Passieve aanvallen

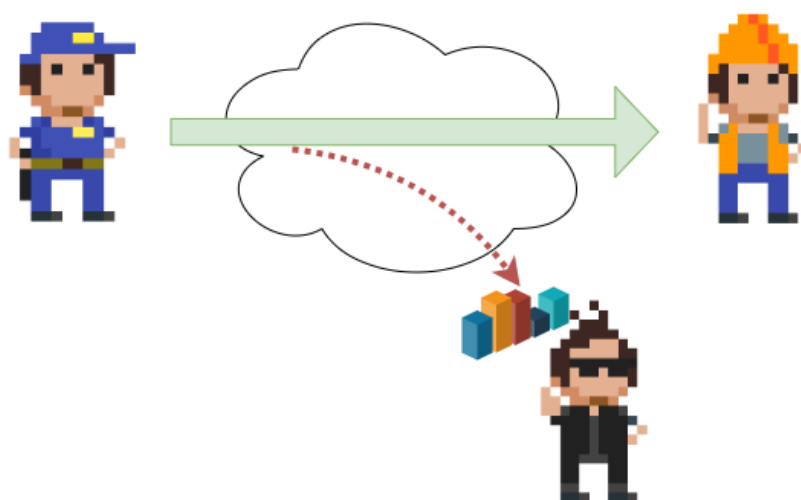
Bij een **sniffing** aanval gebruikt Eve een *sniffer* (bijvoorbeeld Wireshark indien ze netwerk-traffic wenst te meten) om alle communicatie tussen twee eindpunten te zien. Alhoewel data steeds vaker geëncrypteerd wordt, zal Eve toch vaak erg nuttige informatie uit deze moeilijk te detecteren aanval kunnen halen. Denk maar aan MAC-adressen, algemene gebruikersinfo, etc. We staan er niet altijd bij stil hoeveel netwerk-traffic tegenwoordig constant over netwerken over en weer vliegt. Daarbij komt ook een iets recenter fenomeen: de minder veilige third-party apps van bekende merken. Applicaties gemaakt door derden volgen mogelijk niet altijd de strenge beveiligingscriteria van het bedrijf waarvoor ze een app hebben gemaakt. Hierdoor bestaat er de kans dat sommige apps zelfs flagrante fouten maken en bijvoorbeeld user credentials onbeveiligd opslaan, of erger, over het netwerk sturen. Dit soort apps maken het werk voor Eve die aan het sniffen is dan ook erg gemakkelijk.



Figuur 3.5: Passieve aanval, type 1: Sniffing.

Soms is geen traffic kunnen sniffen ook nuttig voor Eve. Later behandelen we nog side-channel

aanvallen, maar we bespreken nu toch al deze vaak vergeten broer van de sniffing-aanval: de **trafiek analyse**. Door het registreren wanneer en hoe een doel communiceert kan Eve ook erg veel informatie op een passieve manier te pakken krijgen. In de eerste plaats laat het de stroper toe om te weten wanneer een gebruiker actief is en wanneer niet. Sommige systemen laten een alarm afgaan als ze zien dat een legale gebruiker op een onverwacht moment actief is, iets waar Eve nu rekening mee kan houden. Voorts laat het Eve ook toe om te ontdekken wat voor activiteiten het slachtoffer gebruikt (zijn er veel e-mail-gerelateerde berichten? Of net veel VoIP-calls?).

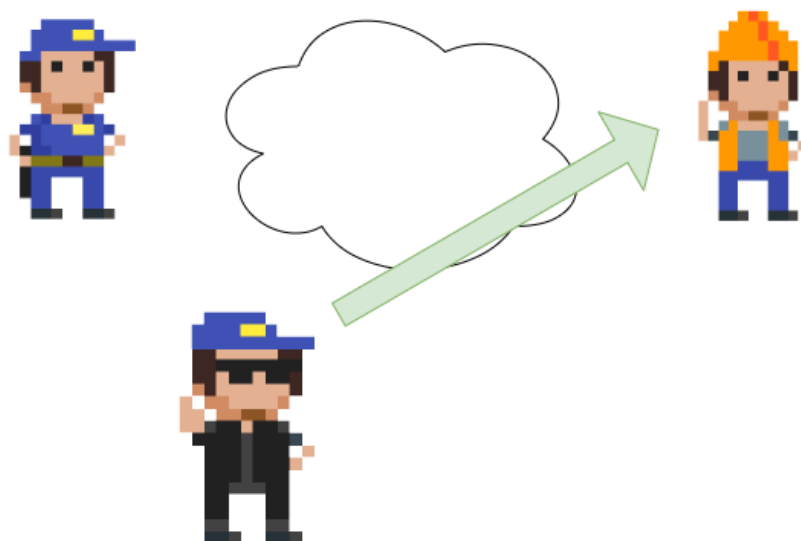


Figuur 3.6: Passieve aanval, type 2: Trafiek analyse.

3.5.2 Actieve aanvallen

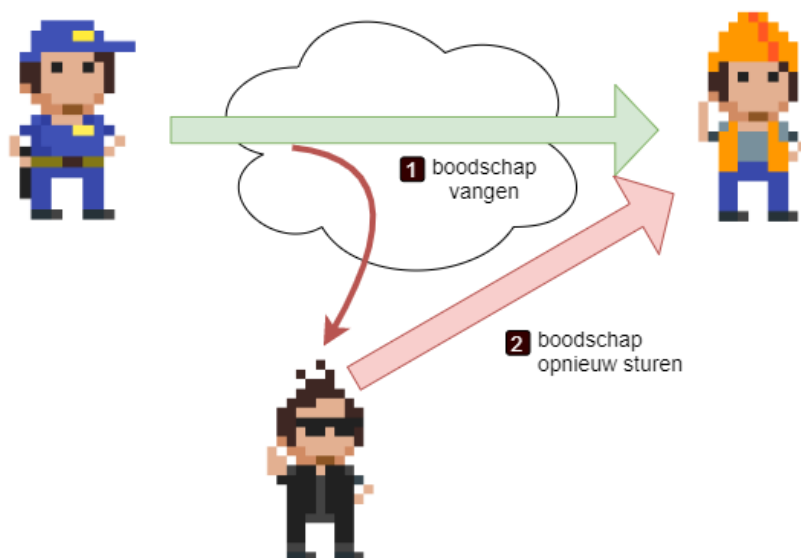
Het domein van de actieve aanvallen is natuurlijk het domein waar Eve de meeste slaagkansen zal produceren, maar ze heeft ook een veel hogere kans op gevat te worden. Om die kans te verkleinen zal de stroper bijna altijd de aanval uitvoeren door zich als iemand anders voor te doen: *masquerading*. Via **spoofing** zal de stroper de digitale identiteit van een legitieme gebruiker overnemen (denk maar aan MAC-spoofing waarbij Eve het hardware adres van een bedrade of draadloze netwerk-kaart overneemt). Masquerading heeft een dubbel doel:

1. Het zal de daaropvolgende aanvallen moeilijker kunnen linken aan Eve, daar ze onder een pseudoniem actief is.
2. Het zal Eve mogelijk toegang verschaffen tot bronnen waar ze onder haar eigen *identiteit* niet de juiste rechten toe heeft.



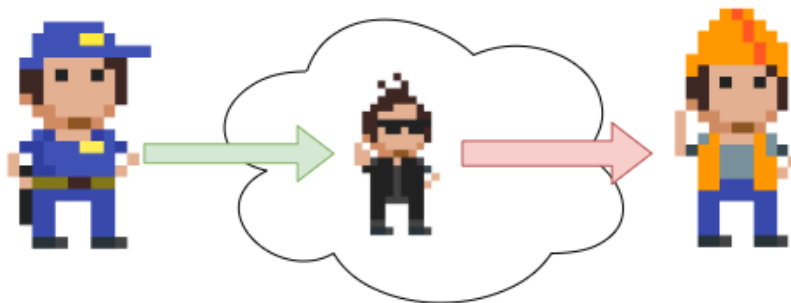
Figuur 3.7: Actieve aanval, type 1: Masquerading.

Het tweede type actieve aanvallen zijn **replay**-attacks. Hierbij zal de stroper eerder bewaarde, legitieme, communicatie heruitzenden in de hoop dat de ontvanger er zich geen vragen bijstelt. Beeld je in dat Eve een login-pakket heeft gesnift van een erg zwak beveiligd systeem: als Eve de volgende dag wil inloggen onder de naam van haar slachtoffer dan hoeft ze enkel dat bewaarde pakket opnieuw te versturen.



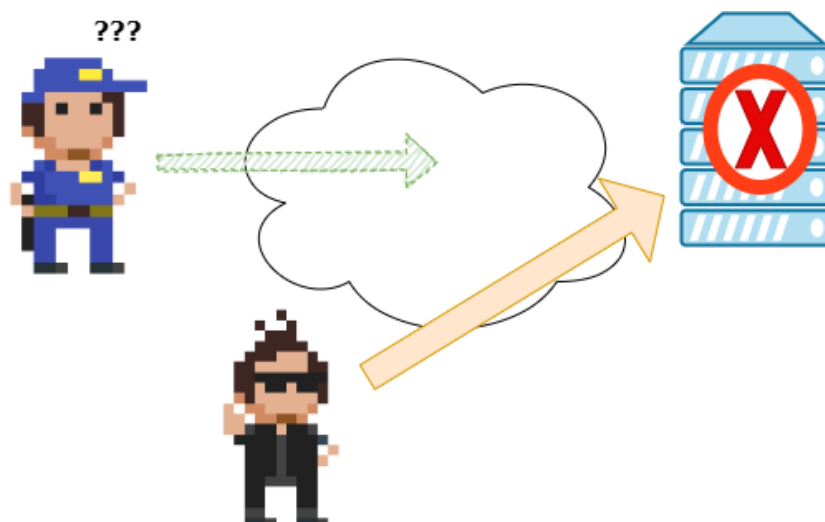
Figuur 3.8: Actieve aanval, type 2: Replay attack.

Type 3 is vanuit het standpunt van de aanvaller de interessantste: de **man-in-the-middle** of **MitM**-aanval. Hierbij zal Eve zich tussenin de communicatie van Bob en Alice nestelen met als doel op een onzichtbare manier hun communicatie te lezen, aanpassen of blokkeren. Het laat Eve toe als een soort *puppetmaster* de volledige communicatie te bepalen en beïnvloeden. Deze aanval is erg krachtig, maar vereist ook vaak een stevige technische opbouw door Eve daar ze nu twee eindpunten heeft die ze met behulp van onder andere masquerading moet aanvallen.



Figuur 3.9: Actieve aanval, type 3: Man-in-the-middle aanval.

Als laatste de meest voorkomende aanval: de **Denial-of-Service** (DoS). Deze aanval heeft als doel om een systeem of gebruiker *lam te leggen* zodat deze niet meer voor andere gebruikers of systemen bereikbaar is. De reden om een DoS uit te voeren zijn velerlei en de manier waarop deze uitgevoerd kan worden is ook quasi eindeloos: de stekker uittrekken, gigantische hoeveelheden communicatie versturen, of het signaal verstoren met een microgolf-oven. Alles is mogelijk en het hangt vooral van de creativiteit van de aanvaller af hoe effectief de aanval is.



Figuur 3.10: Actieve aanval, type 4: Denial-of-Service aanval.

3.6 Hoe verdedigen

Wat en wie je wilt verdedigen in de cyberwereld kan erg gevarieerd zijn. Toch kunnen we alles herleiden tot 4 + 1 fundamentele principes die je best hanteert indien je een systeem van welke vorm ook wenst te beschermen tegen cyberstropers. Deze zijn:

- **Layering:** bouw je beveiliging zoals de lagen van een ui rondom je te beschermen data, gebruikers en services. Hoe meer lagen hoe beter, op voorwaarde dat ze natuurlijk verschillend zijn. Het voordeel van met meerdere lagen werken is evident: indien één laag om welke reden dan ook gecompromitteerd raakt, zijn er nog steeds de andere lagen die als verdediging werken.
- **Limiting:** beperk steeds maximaal wat iedereen binnen je systeem kan. Zorg ervoor dat gebruikers en services enkel die zaken kunnen doen waartoe ze recht hebben volgens hun rol. Geef dus niet iedereen admin-rechten, zet je firewall niet op *allow all*, etc.
- **Diversity:** zorg ervoor dat je een verscheidenheid aan beveiligingen hebt. Op die manier voorkomen we, net als bij layering, dat het falen van één systeem je hele verdediging neerhaalt.
- **Simplicity:** KISS, oftewel *keep it simple, stupid*. Al het voorgaande lijkt te doen uitschijnen dat je complexe systemen moet bouwen die als het ware een doolhof voor de aanvallers maken. Op zich is daar iets van aan, maar zorg er wel voor dat je niet zelf in je doolhof verdwaalt en daardoor fouten introduceert zonder het te beseffen. Soms is *less more* en dat geldt ook bij beveiliging.



Het vijfde fundamentele principe krijgt een eigen kadertje omdat deze voor discussie vatbaar is én geregeld voor de nodige controverse kan zorgen. Als je dus, om welke reden dan ook, niet genoeg tijd of budget hebt om alle principes toe te passen, probeer dan de volgende als laatste “oplossing” te gebruiken:

- **Obscurity:** ga niet aan de grote klok hangen hoe jouw verdediging is opgebouwd. Echter, let op met deze leuze. Obscurity wil niet zeggen dat je zelf een of ander vaag crypto-algoritme zelf gaat ontwikkelen en angstvallig gaat geheim houden. Gebruik standaarden en vertrouwde producten in je beveiliging. Eén van de eerste regels in security is “ga niet zelf het wiel heruitvinden”!



Soms zal je digitale stropers horen spreken over “Ik heb dat systeem gepwnd”, uitgesproken als *ge-powned*. De term “to pwn” is *hacker-slang* voor “to own” om aan te geven dat je in een systeem bent binnen geraakt en nu controle over het systeem hebt. Volgens de urbandictionary.com is de enige reden dat de *o* een *p* werd het gevolg van een typfout, daar beide letters vlak naast elkaar staan op een toetsenbord.

3.7 Social Engineering

In het eerste hoofdstuk kwam de term “Social engineering” al enkele keren voor. We zagen ook bij de McCumber kubus dat we niet enkel op technologie mogen rekenen wanneer we onze verdediging opzetten, maar dat we ook een heel belangrijke schakel moeten trainen en opvolgen: de mensen. Mensen zijn meestal de zwakste schakel in ons securitymodel en dus daarom ook een interessante “aanvalsvector” voor digitale stropers.

Social engineering wordt ook wel eens *het hacken van mensen* genoemd en is een erg laagdrempelige, maar oh zo effectieve aanvalstechniek die vaak over het hoofd wordt gezien. Bij social engineering zal de aanvaller *menselijke* interacties gebruiken om zijn slachtoffers onbewust zaken te laten doen of informatie te geven dat niet zou mogen. Hierbij misbruikt de aanvaller onze aangeboren gewoonte om mensen te vertrouwen in plaats van te wantrouwen. We gaan meestal uit *van het goede van onze medemens* en zullen vaak meerdere goede redenen kunnen verzinnen waarom iemand iets van jou nodig heeft. Andere menselijke trekken die we kunnen gebruiken als social engineer zijn onder andere de nieuwsgierigheid van mensen, hun hebzucht, onwetendheid of angst.

Enkele voorbeelden:

- Je verkleden als pizzakoerier en een grote stapel (lege) pizzadozen het bedrijf binnendragen. Werknemers zullen je willen helpen en de deur voor je openhouden, ook al moet je normaal gezien met je toegangsbadge het gebouw betreden.
- Bij de rokers aan de achterkant van het gebouw gaan staan, wat met hen keuvelen en hen sigaretje aanbieden. Wanneer ze terug binnengaan hen volgen (*piggybacking*).
- Bellen en je voordoen als een techniker van Telenet en vervolgens de login-gegevens vragen van het slachtoffer.

Uiteraard hoeven social engineers zich niet te beperken tot *fysiek* contact. Ze hanteren ook erg vaak geschreven teksten (e-mail) om aan social engineering te doen. Hierbij onderscheiden we twee soorten:

- **Phishing:** trachten zoveel mogelijk mensen naar een bepaalde website of document te lokken waar vervolgens de aanvaller informatie van het slachtoffer zal proberen te verkrijgen door een

fake login scherm te tonen, malware ongezien te installeren, etc.

- **Spear phishing:** deze vorm van phishing heeft als doel één persoon of groep. De e-mail zal dan ook opgesteld worden om specifiek voor het slachtoffer te werken, i.p.v. een generieke mail.



De term *phishing* is afgeleid van *fishing* oftewel vissen/hengelen naar iets. Vroeger had je het concept *phreaking* dat werd toegepast door hackers om op telefooncentrales in te breken door de 2600 hertz fluittonen die telefoons gebruiken te imiteren.

3.7.1 OSINT

We zagen reeds de vijf fasen die een aanvaller doorloopt: verkennen, scannen, etc. Aangezien Social engineering ook een vorm van cyber-aanval is, zullen ook hier deze fasen worden doorlopen. Zeker bij spear phishing wil de aanvaller zoveel mogelijk informatie over zijn slachtoffer(s) te weten komen om zo de meest doeltreffende mail op te stellen. OSINT, oftewel Open Source INTelligence, is de techniek waarbij een aanvaller open-source bronnen gebruikt om zijn slachtoffers in kaart te brengen tijdens deze eerste verkenning- of reconnaissance fase.

Enkele nuttige technieken die worden toegepast:

- Google en andere searchengines: besef dat je veel meer informatie kunt vinden indien je ook geavanceerde search-eigenschappen gebruikt (denk aan “site:” en de “+”-operator, etc. in Google).
- Reverse image searching: er zijn tegenwoordig erg krachtige tools om de oorsprong van een afbeelding te traceren, en met bijvoorbeeld Google Lens kan je zelfs objecten en locaties op een foto identificeren.
- Metadata van bestanden: media bestanden (.docx, .jpg, .png, .mp4, etc.) bevatten ook aardig wat onzichtbare informatie die soms onbedoeld meereist met het bestand (denk bijvoorbeeld aan de EXIF data in een afbeelding) en dus door kwaadwillige personen misbruikt kunnen worden.

Het **OSINT Framework** (via osintframework.com) is ontwikkeld om mensen er op te wijzen hoeveel publieke informatie social engineers (en anderen) over iemand te weten kunnen komen. Het is een griezelig uitgebreide hoeveelheid online bronnen die mooi gecategoriseerd zijn. Hierbij is het op de koop toe belangrijk te beseffen dat enkel open-source bronnen worden gebruikt. Digitale stropers zullen zich uiteraard niet beperken tot enkel open-source bronnen en ook vaak betaalde of illegaal verkregen bronnen raadplegen.

3.8 Soorten aanvallen

3.8.1 Software-based aanvallen

Software-gebaseerde aanvallen zijn de aanvallen die je in het nieuws geregeld hoort. In deze groep vinden we de virussen, wormen, backdoors, trojans en alle andere **malware** terug. De term malware dekt de lading erg goed: “*any kind of malicious software designed to damage or harm a computer system.*” Het doel van malware is altijd geld, macht (denk aan blackmailen) of pestgedrag. De verschillende malware-types hebben soms overlappende eigenschappen en het is dus niet altijd mogelijk om een specifiek stuk malware onder één categorie te plaatsen. Wat ze allemaal gemeen hebben is dat ze bepaalde gekende of ongekende (*zerodays*) fouten of bugs (*kwetsbaarheden* of *vulnerabilities*) misbruiken in software om zo toegang tot een systeem, data of stuk hardware te verkrijgen.

We overlopen nu de belangrijkste vormen van malware.

3.8.1.1 Virus

De moeder van de malware. Hiermee is alles begonnen. De eerste virussen werden geschreven door scriptkiddies en mensen met te veel tijd. Ze hadden zelden een specifiek doel, en wilden gewoon zien wat de kracht van een virus was en hoe ambetant het anderen zou maken. De eerste virussen, in pre-Internet tijd, waren afhankelijk van overdracht via diskettes en raakten dus niet snel verspreid. Virusscanners waren nog onbestaande, maar als je een virus te pakken had dan was dat uiteraard even vloeken: sommige virussen infecteerden je bootsector, zodat je computer niet meer bootte, andere verwijderden bepaalde systeembestanden, enz. Ze werden geactiveerd door een uitvoerbaar bestand uit te voeren (zogenaamde .exe, .bat of .com bestanden) waar het virus zich onzichtbaar aan had vastgeklampt.



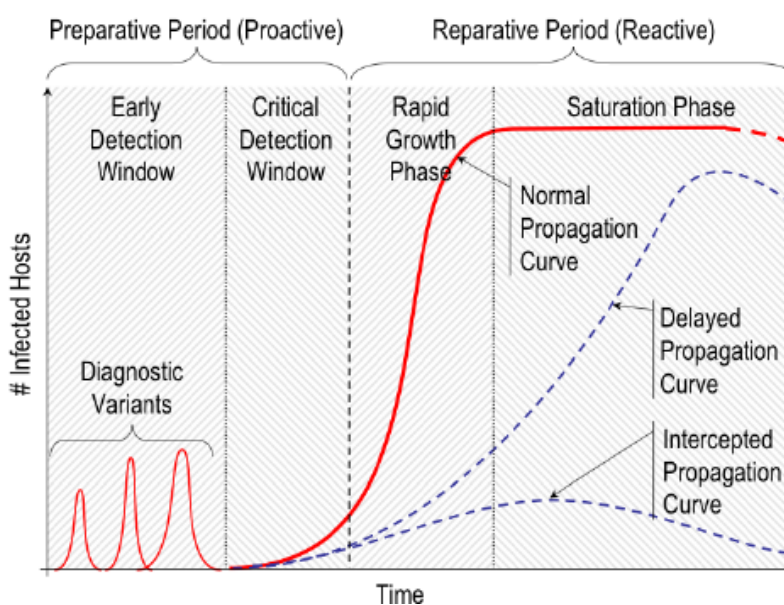
De auteur van dit boek heeft z'n vader een hoop extra grijze haren gekost door z'n game-verslaving. In de jaren 90 was de enige manier om aan games te geraken ofwel via de één of twee computerwinkels in de provincie, oftewel door diskettes van klasgenoten te kopiëren. Geregeld bevatte die gekopieerde games echter ook virussen, met alle gevolgen van dien. Moraal van het verhaal: *don't pirate, kids ;).*

Heden ten dage komen we nog maar weinig “klassieke” virussen tegen. Je kan zeggen dat ze zijn geëvolueerd naar veel lastigere, soms letterlijke dodelijke varianten zoals wormen, ransomware, etc.

3.8.1.2 Wormen

Een virus is een beetje zoals een giftige vis op het droge: het ligt maar wat in het zand te spartelen en enkel als je zo dom bent om het ding op te rapen en in je aquarium met zeldzame vissen te plaatsen zal het schade kunnen toebrengen. Wormen daarentegen zijn de *sharknados* van de giftige vissen op het droge. Wormen zijn virussen die zichzelf kunnen voortplanten via één of meerdere communicatiekanalen. Uiteraard in de eerste plaats denken we dan aan het Internet as is, maar ook via e-mail, WhatsApp-berichten, Bluetooth, Facebook, etc.

Als bijkomende handigheid zullen wormen ook vaak zichzelf veranderen zodat ze moeilijker door virusscanners kunnen gedetecteerd worden. Voorts hebben wormen geen *hostfile* nodig wat virussen wel hebben. En als laatste verschil met de virusjes is dat wormen zichzelf ook kunnen verspreiden zonder dat de gebruiker een (on)bewuste handeling moet doen. Kortom, wormen zijn een pittig probleem, vooral vanwege de snelheid (en eenvoud) waarmee ze zich verspreiden.



Figuur 3.11: Worm propagation model. Bron: Network Eye: End-to-End Computer Security Visualization - Scientific Figure on ResearchGate.

Bovenstaande afbeelding toont het *worm propagation model*. Dit model toont hoe snel een worm zich kan verspreiden en hoe belangrijk het is om een nieuwe worm zo snel mogelijk te detecteren, in de hoop voldoende systemen vervolgens te beschermen tegen besmettingen ervan. Naarmate een worm meer systemen kan besmetten, die op hun beurt dan ook als uitvalsbasis van de worm dienen, merk je een exponentiële groei van besmette systemen. Deze groei bereikt een plateau wanneer quasi alle systemen besmet zijn die konden besmet worden.

3.8.1.3 Trojan

Trojans zijn malware die zich verstoppen binnenin een legale, al dan niet nuttige, applicatie die de gebruiker bewust installeert of downloadt. Van zodra de gebruiker deze host-applicatie installeert of start zal de onderliggende trojan zijn aanval op het systeem beginnen. Die aanval kan velerlei zijn, denk maar aan het installeren van een backdoor, de computer veranderen in een zombie (zie botnet verderop) of een keylogger activeren.

De naam Trojan is gebaseerd op de legende van Het Paard van Troje uit de Aeneid van Vergilius.

3.8.1.4 Spyware

De naam spyware dekt de lading duidelijk: deze malware heeft als doel om informatie te verzamelen van het doelsysteem, zonder dat de gebruiker hiervan op de hoogte is. Deze informatie kan gaan van eenvoudige gebruikersdata zoals usernames en wachtwoorden, maar gaat soms ook verder tot het in kaart brengen van surfgedrag of op welke manier de gebruiker een specifieke applicatie gebruikt. We kunnen stellen dat spyware twee categorieën heeft:

1. Reclamedoeleinden: hoe beter adverteerders de gebruiker kennen, hoe gericht ze reclame kunnen maken en dus hoe groter de kans wordt dat die gebruiker uiteindelijk een geadverteerd product koopt.
2. Cybercriminelen: de meeste spyware die we heden ten dage tegenkomen verzamelen natuurlijk die dingen waar cyberstropers de meeste interesse in hebben: bankgegevens (logins, kredietkaartinformatie). Het hoofddoel van deze categorie is natuurlijk: centjes!

Spyware wordt meestal als trojan geïnstalleerd nadat de gebruiker een legitiem programma installeerde. Enkele bekende spyware-dragers waren de erg populaire (illegale downloader) Kazaa en Messenger Plus!, de plugin voor Windows Live Messenger.

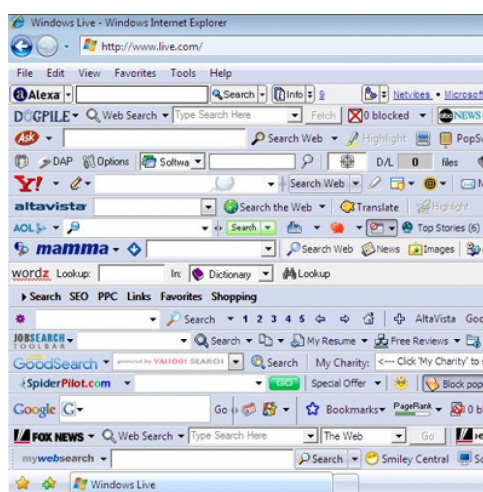
3.8.1.5 Adware

Daar waar spyware soms door adverteerders wordt gebruikt om “het doelwit beter te leren kennen”, heeft adware als doel om effectief reclame aan deze gebruiker, meestal ongewild te tonen. Ongewild is het sleutelwoord hier in. Adware is op zich niet noodzakelijk malware. Veel adware wordt gemaakt zodat de maker ervan extra inkomsten kan genereren om bijvoorbeeld het hoofddoel van de adware te blijven door ontwikkelen. Denk maar aan bepaalde gratis *musicplayers* die ook reclamebanners tonen terwijl je muziek afspeelt. Er is echter ook een categorie adware die **ongewild** reclame toont en soms zelfs op een zodanige manier dat een huis-tuin-en-keuken gebruiker zelfs niet beseft waar de reclame vandaan komt. Eind jaren 2010 had je veel browser-extensies die in je menu-balk als flitsende

knoppen allerlei handige extra hulpmiddelen beloofden. Vaak zorgden deze extensies er echter ook voor dat je tal van extra reclame-pop-ups kreeg die in eerste instantie het gevolg waren van de website waar je op dat moment naartoe surfte.



Een bijkomend probleem van sommige malware is dat ze *rootkit*-achtige (zie hierna) technieken gebruiken waardoor ze erg moeilijk te verwijderen zijn en je moet opletten dat je niet essentiële bestanden van je computer verminkt of verwijderd.



Figuur 3.12: Een wat overdreven voorstelling van het soort browsers vol adware die de auteur soms te zien kreeg toen hij computers ging repareren die “nogal traag waren”. Bron: <https://www.directive.com/blog/disabling-those-pesky-browser-toolbars.html>.

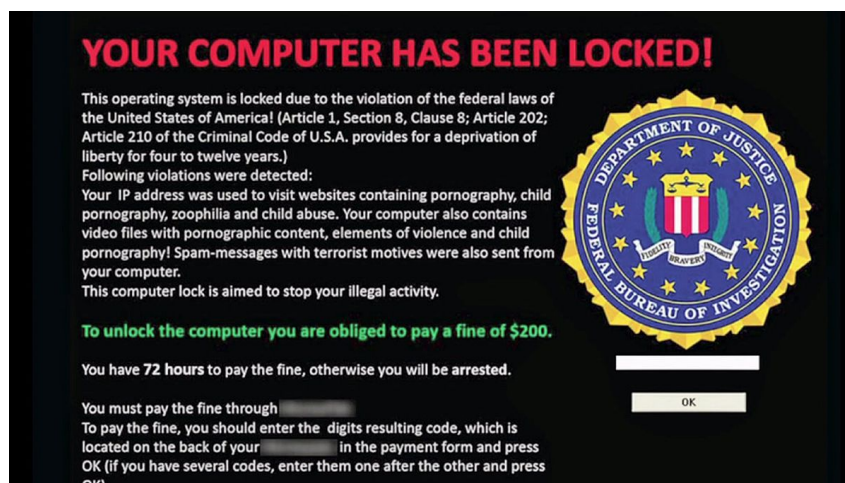
3.8.1.6 Rootkit

Een virus zal zich nestelen op “gebruikersniveau”, terwijl een rootkit zich veel dieper in het besturingssysteem zal nestelen (op *kernel-niveau* of *administrator-niveau*). Hierdoor zijn rootkits veel onzichtbaarder, daar ze ook kunnen bepalen welke informatie de gebruiker van het besturingssysteem te zien krijgt. Een rootkit is eerder een techniek die kan gebruikt worden door de andere vormen van malware die we hier beschrijven. De essentie van een rootkit is natuurlijk dat deze veel robuuster zijn en bijgevolg moeilijker te verwijderen zijn door het slachtoffer. Vaak zal een rootkit ook systeembestanden aanpassen (zie ook de infobox bij adware) waardoor je rootkits niet kunt verwijderen zonder permanente schade aan je besturingssysteem toe te brengen. De enige manier om een rootkit dan goed weg te krijgen is door je harde schijf te formatteren. Je OS opnieuw installeren/resetten, gebruik makend van de

aanwezige installatiebestanden op de computer, is namelijk niet gegarandeerd dat dit voldoende zal zijn: mogelijk heeft de rootkit zich ook al in de installatiebestanden op de harde schijf geïnstalleerd!

3.8.1.7 Ransomware

De plaag van de laatste jaren! Het einddoel van cybercriminelen is natuurlijk centjes. Als je virus al je bestanden verwijderd dan heeft een digitale stroper weinig *leverage* om nog geld van z'n slachtoffer te pakken te krijgen. Ransomware lost dit probleem op voor de stropers: het zal de data letterlijk gijzelen en losgeld (*ransom*) vragen aan de gebruiker. Wanneer een ransomware op een systeem geraakt (via bijvoorbeeld een trojan of worm) zal het de data van de gebruiker versleutelen met een sleutel die enkel de maker van de malware kent. Vervolgens verschijnt er een bericht op de computer met daarin wat de gebruiker moet doen (betalen) indien deze z'n data terug wenst. Meestal zal de ransomware betalingen in crypto-coins vragen zodat het geld niet kan getraceerd worden.



Figuur 3.13: Voorbeeld van een typisch ransomware scherm dat het slachtoffer te zien krijgt (Bron: wikipedia).

Ransomware heeft aangetoond dat back-ups maken van je data erg belangrijk is. Maar ook HOE en WAAR je back-up'd zal invloed hebben op hoe ransomware-gevoelig je bent. Indien je back-ups maakt op hetzelfde systeem als waar de originele data staat, dan bestaat de kans dat de ransomware ook de back-up zal *gijzelen*. Indien je niet op geregelde tijdstippen een back-up neemt kan het zijn dat je dagen of weken aan data kwijt bent moest je het slachtoffer van een ransomware-aanval zijn. We gaan niet verder in op back-up strategieën, maar het mogelijk duidelijk zijn dat deze *skillset* een essentieel onderdeel vormt van het *security-beleid* van een bedrijf.



Herinner je dat de ransomware-aanvallen uit hoofdstuk 1 (WannaCry en Petya in 2017) ook meer impact hadden dan enkel “dataverlies”: ziekenhuizen moesten patiënten de toegang ontzeggen, containerbedrijven zaten met duizenden tonnen aan vracht die niet verscheept geraakten.

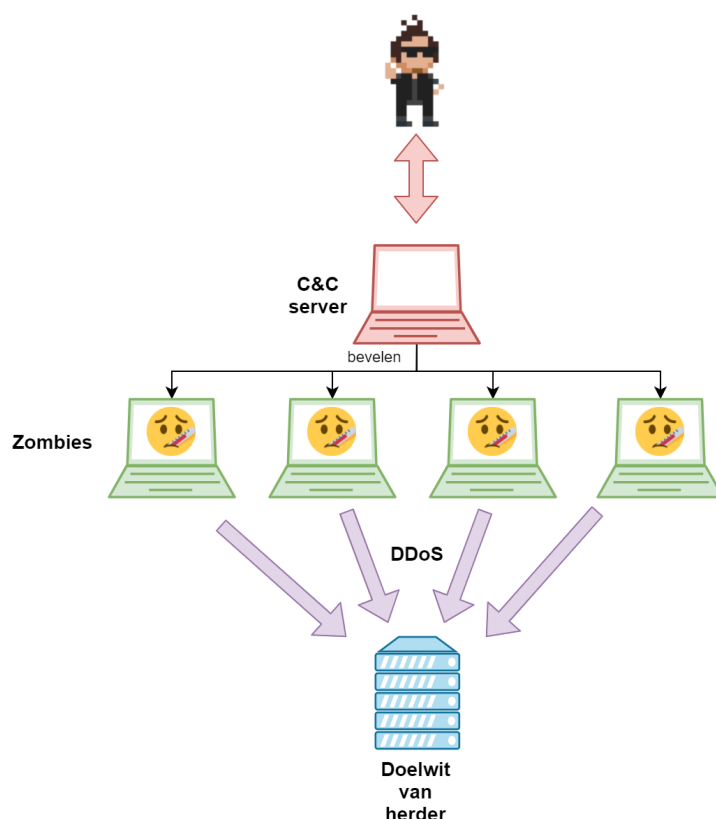
3.8.1.8 Botnet

Wat als een stroper toegang had tot een legioen computers? Duizenden computers die naar het bevel van de cybercrimineel luisteren en zonder morren doen wat hen gevraagd wordt? Welkom in de wondere wereld van botnets, zombies en herders.

Wanneer een cybercrimineel een grote groep computers nodig heeft, dan zal deze via voorgaande malware-technieken proberen zoveel mogelijk computers te besmetten met zijn *zombie-virus*. Dit virus zal twee dingen doen:

1. Het zal zich onzichtbaar nestelen op de computer en ervoor zorgen dat het virus ook na heropstart actief is (*maintain access*).
2. Het zal een backdoor creëren en terugbellen naar de *command-en control-server* (**C&C server**) van de originele virusmaker, de zogenaamde *herder*.

Via de C&C-server kan de botnet-herder nu alle zombies benaderen en bevelen geven. Het kan de zombies bijvoorbeeld vertellen dat ze allemaal tegelijkertijd naar een bepaalde website moeten pingen, waardoor een gigantische DDOS (*Distributed DoS*)-aanval plaatsvindt. Of het zou kunnen bevelen dat alle zombies vijf sterren moeten geven aan een specifieke applicatie in de app-store. Of wat te denken van duizenden zombies die permanent als cryptominers naar bitcoins delven voor de herder?



Figuur 3.14: Een echte botnet zal veel meer dan vier zombies bevatten. Maar we moeten ergens mee beginnen, nietwaar.

Hoe groter het botnet, hoe krachtiger en machtiger de herder is. Botnets kunnen zoveel impact hebben op systemen dat er een hele ecologie rond illegale botnets is verschenen. Zo zijn er websites waar herders de diensten van hun botnets verhuren aan anderen (*botnets-as-a-service*) of gewoon geregeld hun nieuwst verzamelde botnet verkopen aan de hoogste bidder op het darkweb.

Het is in het voordeel van de herder dat botnets zo onzichtbaar mogelijk blijven. Daarom dat de meeste botnet-software heel subtiel op de achtergrond werkt. Veel computers maken maanden, soms jaren, deel uit van een botnet zonder dat ze dat ooit hebben beseft.

Omdat botnets zo'n grote impact kunnen hebben, jagen Microsoft, Cisco, McAfee, etc. actief op deze zaken. Een botnet uitschakelen door de zombies te bestrijden is natuurlijk onbegonnen werk. De oplossing ligt natuurlijk bij de C&C-servers! Als je die server uit de lucht krijgt dan zijn de zombies nutteloos en heb je letterlijk het botnet onthoofd.

3.8.2 Netwerk-based aanvallen

Een groot deel van de aanvallen gebeurt uiteraard via een bedraad of draadloos netwerk. We spenderen een volledig apart hoofdstuk aan draadloze aanvallen verderop in dit handboek. De meer *klassieke* netwerk-gebaseerde aanvallen komen niet in dit handboek voor. Er zijn ongelooflijk veel mogelijkheden op netwerk/communicatie-niveau om als cybercriminal toegang tot systemen te verkrijgen. Ieder bekend protocol (DNS, IP, TCP, CSMA/CD, SNMP, etc.) heeft ontelbare, gekende, bugs. Nog steeds worden er nieuwe technieken ontwikkeld, zelfs bij protocollen die al 20 tot 30 jaar bestaan (om je een idee te geven: het IP-protocol werd in 1977 geschreven).

3.8.3 Hardware-based aanvallen

In den ouden tijd leken aanvallen vooral een software gebeuren. Enkel in de duurdere Hollywood-films werden er ingewikkelde hardware-apparaten gebruikt door stropers om toegang tot streng beveiligde systemen te verkrijgen. Tegenwoordig kan je voor enkele dollars ongelooflijk krachtige Raspberry Pi's, Arduino, etc. kopen, waardoor hardwaregebaseerde aanvallen steeds vaker voorkomen (je zou kunnen spreken van een democratisering van *hacking hardware*).

Dit hoofdstuk zou wederom een heel eigen boek kunnen bevatten, we gaan daarom enkele van de meest voorkomende of interessantste zaken kort toelichten. Net zoals met malware zal je merken dat er soms overlap is tussen verschillende type aanvallen en het dus zeker geen zwartwit classificatie is:

- **USB sticks:** deze kleine dingen kosten nog geen euro als je ze in bulk koopt. Ideaal dus om ze als aanvaller te vullen met malware die zichzelf automatisch installeert wanneer een slachtoffer de stick goedbedoeld in z'n computer steekt. Of wat te denken van een *USB of death* die 220 volt door je computer jaagt als je hem insteekt, gegarandeerd dat je daarmee een DoS aanval kunt uitvoeren want de stick zal het moederbord, de harde schijven etc. vernietigen door de hoge stroomstoot.
- **BIOS rootkits:** in moderne computers zitten BIOS chips die voorkomen dat je zomaar eender welke software kan inladen bij het opstarten - met dank aan UEFI dat onze systemen beveiligt met systemen zoals Trusted Platform Modules (TPM), Secure Boot, etc. Maar wat als je er in slaagt om die chip te hacken? Recent dook *Moonbounce* op, UEFI malware die aanvallers als een springplank kunnen gebruiken om vervolgens andere malware op het systeem te krijgen. De sterkte van Moonbounce? Het kan zichzelf in de chip installeren en blijft permanent aanwezig zodat je besturingssysteem verwijderen of harde schijf formatteren geen zin heeft.
- **Raspberry Pi, Arduino, Malduino and friends:** computers die niet groter dan een dikke duim zijn. De mogelijkheden zijn natuurlijk immens wat je kan doen als je dit soort dingen onzichtbaar kan inplanten in een bedrijf. Doordat dit soort dingen zo goedkoop zijn geworden zien we ook

vaker concepten zoals **warshipping** opduiken: een aanvaller verstuurt zijn geautomatiseerde Raspberry Pi naar z'n slachtoffer door het toestel in een gewoon postpakket te verstoppert in bijvoorbeeld een dubbele bodem. Van zodra het pakket aankomt, zal het toestel automatisch proberen verbinding te maken met het aanwezig netwerk en *terugbellen* naar de aanvallers. Zolang het slachtoffer de Raspberry Pi niet detecteert kan de stroper vanuit de veilige haven van z'n huis aanvallen uitvoeren.

- **Keyloggers en juice hacking:** keyloggers bestaan zowel in software als hardware, maar hun doel is natuurlijk hetzelfde: de toetsaanslagen van het slachtoffer detecteren om er dan bijvoorbeeld wachtwoorden en gebruikersnamen uit te filteren. Hardware keyloggers worden door stropers vaak aan een systeem gehangen waar ze niet permanent toegang tot hebben. Enkele dagen of weken later moet de stroper dan enkel de keylogger ophalen. Gerelateerd hieraan is juice hacking, een fenomeen dat hier en daar opduikt. In publieke plaatsen zijn er meer en meer publieke oplaadpunten waar gebruikers hun digitale toestellen via een USB-draad kunnen opladen. Maar hoe zeker ben je eigenlijk dat die draad die in de muur verdwijnt niets meer is dan een *oplaadkabel*? Wat als aan de andere kant van de muur de draad aan het toestel van de stroper hangt?
- **USB Ninja, RFID cloners en consoorten op lab401.com en hak5.org:** er zijn vele websites waar je tegenwoordig gespecialiseerde *hacking hardware* kunt kopen. Wat te denken van de USB Ninja? Een *gewone* USB-kabel die echter een ingebouwde verzender heeft en automatisch alle data via een RF-verbinding naar de stroper verderop verstuurt. RFID cloners vind je ook voor een habbekrats en laten je toe om de alomtegebruikte RFID toegangskaarten te clonen, zodat de stroper beveiligde gebouwen kan binnenstappen zonder een alarm te laten afgaan.

3.8.4 Side-channel aanvallen

De persoonlijke favoriet van de auteur vanwege de inventieve aanvallen die onder deze categorie bestaan. Het idee van een side-channel aanval bestaat er uit dat je informatie te pakken krijgt uit een protocol of hardware op onverwachte manier. Een vergelijking in het echte leven zou het volgende kunnen zijn: je wil inbreken bij een bank verderop in de straat. Dit gaat echter enkel wanneer de bewaker slaapt. Na observatie heb je ontdekt dat de bewaker voor het slapengaan altijd een boek leest en z'n progressie ervan op GoodReads deelt. Je hebt geen toegang tot de slaapkamer van de bewaker, maar je volgt hem wel op GoodReads. Van zodra de bewaker een update over z'n voortgang post weet je dat het tijd is. Dit is een voorbeeld van een side-channel aanval.

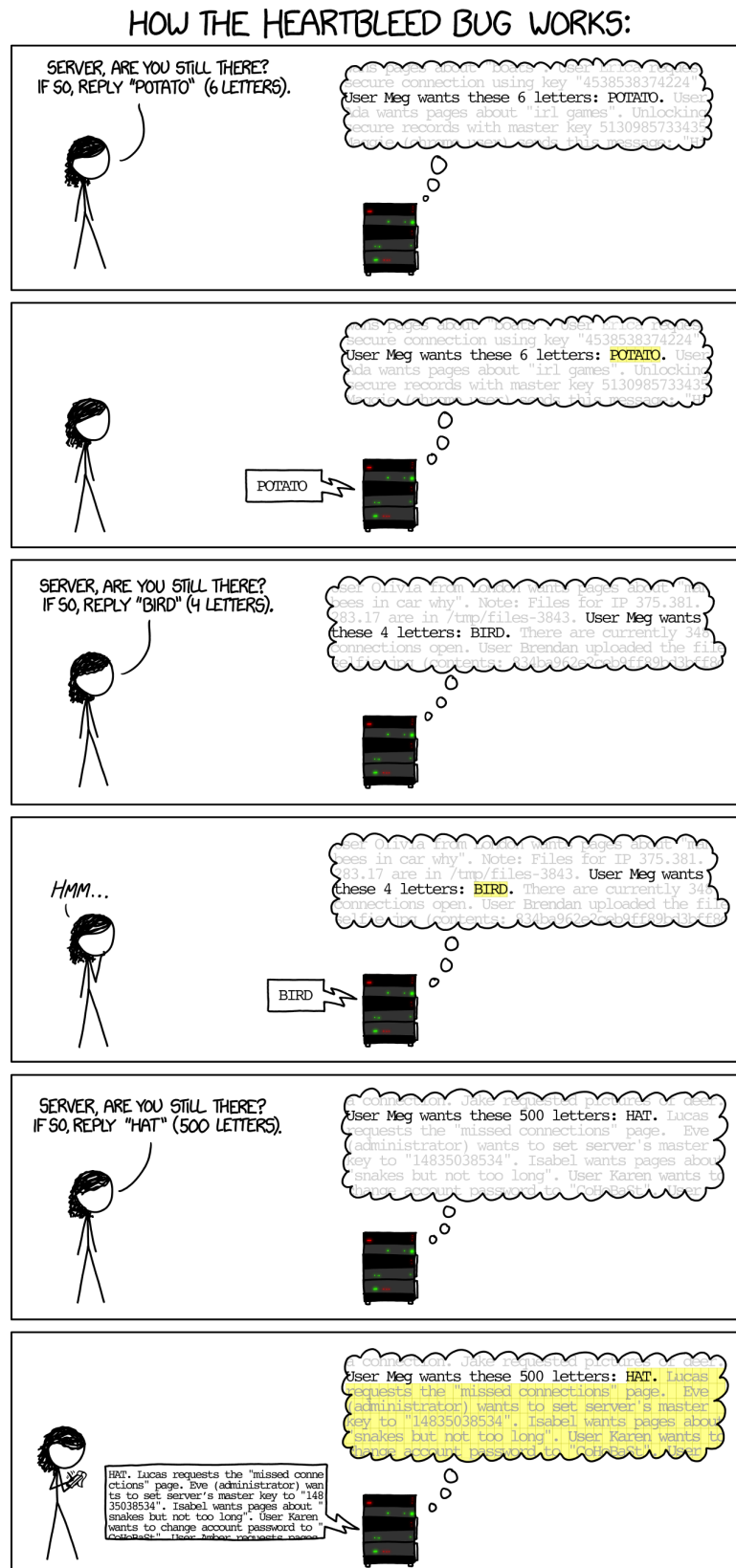
Ieder stuk hardware, software of protocol is vatbaar voor side-channel aanvallen. Het is onmogelijk om 100% hiertegen beschermd te zijn. Uiteraard zijn niet alle aanvallen even effectief als de andere, en alles hangt dus af van wat de stroper juist nodig heeft.

Enkele voorbeelden:

- Militairen deelden hun workouts op Strava. Ze waren echter vergeten dat ze in een geheime basis in Afrika werkten. Plots zagen mensen workouts *in the middle of nowhere* gedeeld worden, wat deed vermoeden dat er op die plaats meer was dan enkel een lege woestijn. Oeps.
- Onderzoekers zijn er in geslaagd om data uit een computer te krijgen door de *power consumption* op te meten.
- Rowhammer, spectre (en ook drammer en rampage) zijn recente technieken waarbij de informatie uit het geheugen kan gelezen worden waar de stropers eigenlijk geen rechten toe heeft.
- Heartbleed: deze bespraken we al kort in het eerste hoofdstuk. Deze inventieve techniek maakt gebruik van het feit dat computers altijd braaf antwoorden als je ze vragen stelt. Maar stropers ontdekten dat de snelheid van antwoorden afhing van de vraag.



Wist je dat een oud liedje van Janet Jackson kan gebruikt worden om (oude) laptops te doen crashen door het gewoon af te spelen? Over een side-channel DoS aanval gesproken. De aanval heeft zelfs een CVE-nummer toegewezen gekregen! Lees hier hoe de aanval werkt: <https://www.bleepingcomputer.com/news/security/janet-jacksons-music-video-is-now-a-vulnerability-for-crashing-hard-disks/>



Figuur 3.15: De briljante xkcd.com strip legt perfect uit hoe Heartbleed werkt.

4 GDPR

De General Data Protection Regulation (2018), of in het Nederlands de *Algemene Verordening Gegevensbescherming* is een Europese richtlijn om de privacy van Europese burgers, eender waar in de wereld, te beschermen. Of zoals de EU zelf op haar website beschrijft: “the toughest privacy and security law in the world” (wat ook effectief zo is: het is de enige wet momenteel die erin slaagt om wereldwijd de regels ervan af te dwingen).

De wet zelf bestaat uit 99 verschillende artikels waarin de rechten, personen en verplichtingen van bedrijven die onder de verordening vallen, worden uitgelegd. Ieder bedrijf, eender waar in de wereld, die data bijhoudt van EU-burgers dient zich aan deze wet te houden op risico van een boete als ze dit niet doet. GDPR gaat dus niet over de verplichtingen van de personen, wel om die van de bedrijven, namelijk ter bescherming van personen.



We gaan in dit hoofdstuk enkel een high-level overzicht geven van GDPR opdat we niet verzanden in de taal der rechters en advocaten, het *legalese*.

4.1 Wat omvat GDPR?

Het recht om persoonlijke gegevens te wissen of het recht om vergeten te worden. GDPR laat je toe, als EU-burger om eender welke site die ‘jou kent’ te verplichten alle, of specifieke, informatie over je te verwijderen. Als je dus vindt dat Google niet moet weten waar je huisadres is, dan heb je het recht Google te verplichten deze informatie te verwijderen.



Google kreeg een tijd terug een zeer stevige boete omdat het niet inging op de vraag van een EU-burger om *vergeten te worden*. Sindsdien zijn ze een pak behulpzamer in het naleven van de GDPR-wetgeving.

Een ander belangrijk aspect van GDPR is het zogenaamde **recht op overdraagbaarheid van gegevens**. Voor GDPR bestond was het soms een helse opdracht om bijvoorbeeld van Internetprovider

te veranderen. Iedere provider werkte met eigen dataformaten waarin de klantgegevens werden bewaard. Bij een overdracht moest dit dan altijd omgezet worden naar het formaat van de nieuwe provider. GDPR verplicht dat dit soort data overdrachten van persoonsgegevens nu volgens een vast formaat moeten gebeuren. En belangrijker: deze overdracht moet zo transparant én zo geautomatiseerd mogelijk gebeuren. Hierdoor kan de data quasi ogenblikkelijk in de database van de ontvanger geïntegreerd worden en zal jij als klant dus veel sneller de overstap kunnen maken zonder alle bijhorende administratieve rompslomp en vertragingen.



De voorganger van de GDPR was de DPD (Data Protection Directive). Dit was geen Europese wet (verordening) maar een aanbeveling en was een stap in de goede richting maar ging nog niet ver genoeg. GDPR heeft ervoor gezorgd dat individuele burgers geen speelbal meer zijn van de grote bedrijven die de data van burgers als het nieuwe goud verzamelen en ermee doen wat ze zelf willen.

Als derde belangrijke aspect voorziet GDPR **de plicht om niet noodzakelijke gegevens te laten wissen**.

4.2 Hoe beschermt GDPR mij als burger?

Zoals je uit voorgaande 3 aspecten al merkt staat de (Europese) burger voorop, niet het bedrijf. GDPR is er om de burger te beschermen tegen de bedrijven die data van hen verzamelen. Het stopt echter niet bij deze 3 aspecten. Volgende rechten worden door GDPR beschermd en zijn minstens even belangrijk:

- Recht op **inzage** (*transparantie*): je hebt het recht om te weten welke data een bedrijf over jou heeft.
- Recht op **rectificatie**: je hebt het recht om foute data te laten corrigeren.
- Recht op **beperking** van verwerking: je hebt het recht om te eisen dat een bedrijf stopt met het verwerken van jouw data. Ook mogen bedrijven je persoonsgegevens niet oneindig lang bewaren. En moeten er duidelijke richtlijnen zijn over hoe lang ze de data mogen bewaren.
- Recht op **verzet**: je hebt het recht om je te verzetten tegen het verwerken van je data. Uiteraard is een bedrijf niet verplicht om jou dan gebruik te laten maken van hun diensten.
- Recht op **geautomatiseerde besluitvorming**: je hebt het recht om te weten wanneer een bedrijf beslissingen neemt op basis van geautomatiseerde processen.
- Recht op **gegevensportabiliteit**: je hebt het recht om je data in een leesbaar formaat te ontvangen.

- Recht op **gegevensminimalisatie**: bedrijven mogen enkel de data bewaren die ze nodig hebben voor hun dienstverlening.

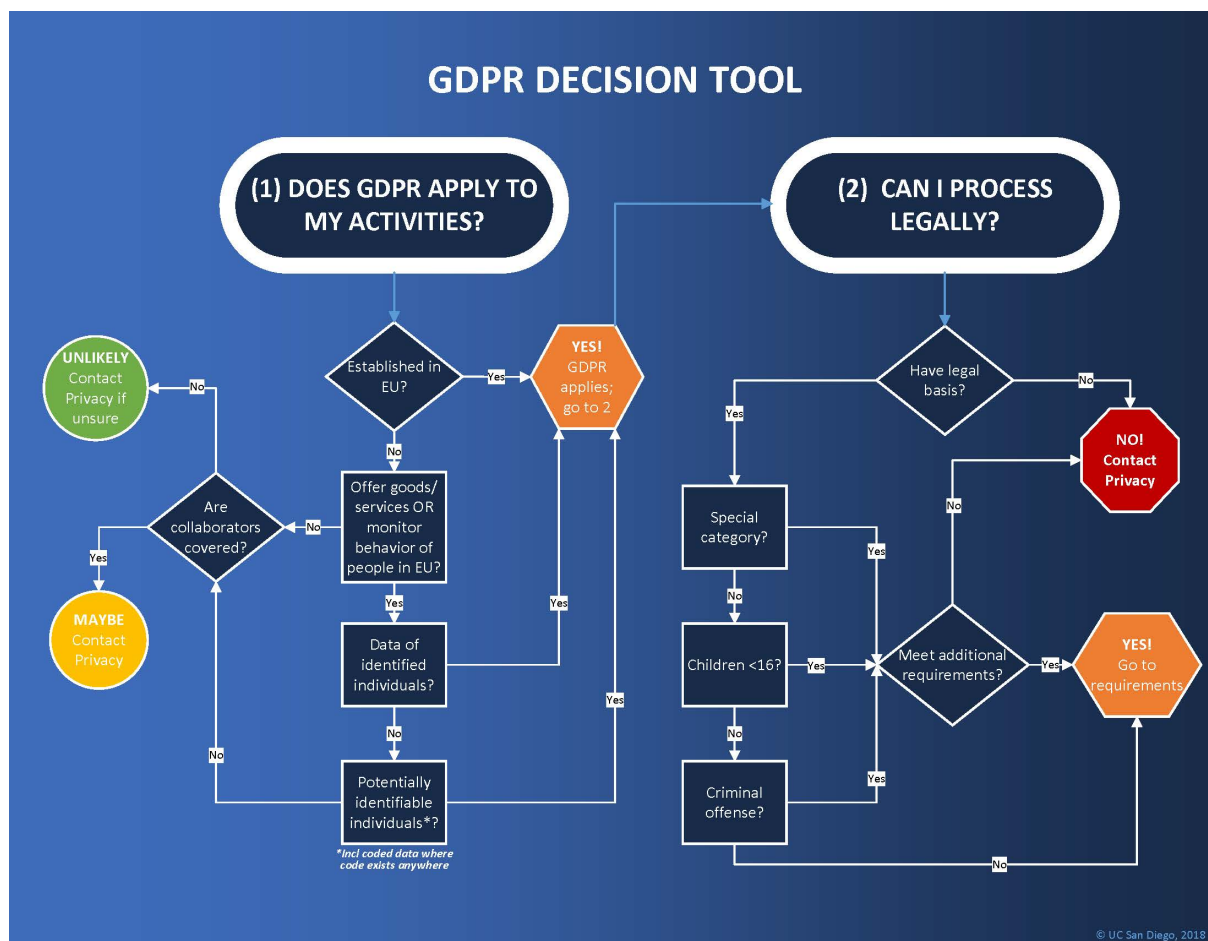
4.3 Wat beschermt GDPR?

De GDPR wet zorgt ervoor dat bedrijven veel bewuster met gebruikersdata omgaan. Ze kunnen namelijk verantwoordelijk gehouden worden indien gebruikersdata gestolen of gelekt wordt. De GDPR is een privacy-wetgeving in de eerste plaats: het wil de privacy van het individu beschermen. Volgende data valt dan ook onder de GDPR-wetgeving:

- Persoonlijke identificeerbare informatie: namen, adressen, geboortedatums en rijksregisternummers.
- Op Internet gebaseerde gegevens: zoals gebruikerslocatie, IP-adres en cookies.
- Gezondheids- en genetische gegevens.
- Biometrische gegevens (denk maar aan je irisscan of vingerafdruk).
- Raciale en/of etnische gegevens.
- Politieke meningen.
- Seksuele geaardheid.

4.4 Persoonlijke data buiten EU

Volgende flowchart toont wat bedrijven, binnen en buiten de EU, met gebruikersdata mogen doen.



Figuur 4.1: Bron: privacy.ucsd.edu/gdpr/

4.5 Meldplicht datalekken

Bedrijven die onder de GDPR-wetgeving vallen (alle bedrijven die data van Europese burgers bewaren vallen hier onder, ongeacht hun locatie in de wereld) hebben een meldplicht indien zij een datalek hebben.



Onder een datalek verstaan we “Een inbreuk op de beveiliging die per ongeluk, of op onrechtmatige wijze leidt tot de vernietiging, het verlies, de wijziging of de ongeoorloofde verstrekking van of de ongeoorloofde toegang tot doorgezonden, opgeslagen of anderszins verwerkte gegevens.”

Van zodra het bedrijf weet heeft van een (mogelijk) datalek dienen zij dit ogenblikkelijk te melden:

- Aan de **toezichthoudende autoriteit**: ieder land heeft z'n eigen autoriteit en in België is dat de **CBPL**, de *Commissie voor de Bescherming van de Persoonlijke Levenssfeer*. Deze commissie zal iedere datalek *case-by-case* beoordelen om te zien of het bedrijf een GDPR-overtreding heeft begaan of niet.
- Aan **ieder individu waar de data betrekking op had**: als de gelekke data ook maar op één manier kan gelinkt worden aan een individu, dan dient deze van de lek op de hoogte gebracht te worden.
- Dit dient **binnen de 72 uur na ontdekking van het datalek te gebeuren**.

Merk op dat tegenwoordig een datalek zelden zo snel wordt ontdekt, dat beseft de GDPR ook. Daarom is de regel dat 72 uur ingaan vanaf het moment dat het bedrijf weet heeft van het datalek. Het is dus perfect mogelijk dat het datalek reeds maanden eerder plaatsvond maar dat het bedrijf het nu pas ontdekt.

4.5.1 Uitzonderingen meldplicht individu

Bij een datalek zijn er enkele mogelijke uitzonderingen waarom het bedrijf niet noodzakelijk het individu op de hoogte moet stellen van het datalek:

- Indien het bedrijf kan aantonen dat de gestolen data zodanig beveiligd is dat deze onbruikbaar is. Als dus de data bijvoorbeeld geëncrypteerd is dan zou het bedrijf dit als argument kunnen gebruiken om de meldplicht te verzaken. Een kanttekening is hier natuurlijk op z'n plaats: er bestaat altijd nog de mogelijkheid dat de data finaal nog kan gedecrypteerd zal worden en er dus alsnog private gegevens in verkeerde handen komen.
- Stel dat het bedrijf de persoonlijke voorkeuren van de gebruikers in een database heeft staan en de identificeerbare persoonsgegevens in een andere. Als nu blijkt dat enkel de database met persoonlijke voorkeuren werd gehackt, dan kan deze data nooit gelinkt worden aan personen en is er dus ook geen sprake van een privacy schending.



Het is sowieso altijd een goede gewoonte om het adagio “*don't put all your eggs in one basket*” te hanteren. Het is wijzer om de data over verschillende databases te bewaren. Zo voorkom je dat bij een datalek automatisch steeds alle data wordt gestolen.



Indien er een erg grote hoeveelheid mensen moeten ingelicht worden na een datalek, dan mag het bedrijf ook beslissen om in de plaats daarvan een publieke aankondiging te doen. Uiteraard zijn de bedrijven hier minder happig op omdat dit sowieso een PR-nachtmerrie is (iedere aankondiging van een datalek is dat trouwens).

4.6 Boetes

Als er uiteindelijk toch een inbreuk op de GDPR-wetgeving wordt vastgesteld dan zal er dus een boete opgelegd worden afhankelijk van de ernst van de inbreuk:

- Minder ernstige inbreuken: boete tot € 10 miljoen, of 2% van de wereldwijde jaaromzet van het bedrijf uit het voorgaande boekjaar, afhankelijk van welk bedrag hoger is.
- Meer ernstige inbreuken (inbreuken die ingaan tegen de principes van het recht op privacy en het recht om te worden vergeten, die de kern vormen van GDPR): boete van maximaal € 20 miljoen, of 4% van de wereldwijde jaaromzet, afhankelijk van welk bedrag hoger is.

Of er een boete zal zijn en hoe groot deze dan is, is gebaseerd op een aantal criteria:

- Ernst en aard van de overtreding.
- Intentie: is het datalek het gevolg van een slordigheid of opzettelijk gebrek aan beveiliging?
- Schadebeperkende omstandigheden.
- Genomen voorzorgen.
- Geschiedenis van overtredingen.
- Medewerking: in hoeverre werkt het bedrijf mee met de toezichthoudende autoriteiten?
- Gegevenscategorie.
- Kennisgeving: heeft men zich aan de meldplicht gehouden?
- Certificering: heeft het bedrijf in het verleden reeds via een externe audit aangetoond aan de GDPR wetgeving te voldoen?
- Verzwarende of verzachtende factoren.



Merk dus op dat het schenden van de GDPR wetgeving niet automatisch in een boete resulteert. Als het bedrijf kan aantonen dat ze echt alles in het werk hebben gesteld om de data te bewaren zoals een goede huisvader betaamt, dan kan het zijn dat er geen boete zal volgen.



De voorbije jaren (mei 2018 tot eind 2020) werden reeds 272 miljoen euro aan boetes geïnd ten gevolge van GDPR overtredingen. De wet is zo effectief, dat ze ook ondertussen dient als inspiratie wereldwijd wanneer landen of groeperingen nieuwe privacy-wetgevingen willen construeren.

4.7 Conclusie

We kunnen dus stellen dat GDPR een zeer mooi waardevol initiatief is, dat ook verder gaat dan “niet toegepaste wetten”. De manier waarop Europese burgers hun data momenteel wordt beschermd is een voorbeeld voor de rest van de wereld. Het is een wet die de privacy van de burger voorop stelt en bedrijven verplicht om hiermee rekening te houden.

Het is nu vooral uitkijken of Europa een soortgelijk voorbeeld kan stellen met de Digital Services Act (DSA) en de Digital Markets Act (DMA) die momenteel in de maak zijn. Deze wetten zullen de macht van de grote techbedrijven zoals Google, Facebook en Amazon moeten inperken en de privacy van de Europese burger nog verder moeten beschermen. Ook de wereld van artificiële intelligentie zal hierdoor grondig veranderen: de AI Act die sinds augustus 2024 gefaseerd wordt ingevoerd zal de manier waarop AI wordt gebruikt in Europa grondig veranderen. Uiteraard, en dat geldt voor alle wetgevingen, is het de uitvoering en de handhaving van de wetten die het verschil zullen maken én wat de impact ervan zal zijn in de concurrentie met de rest van de wereld.

5 Appendix 1: Meer weten

De smaak te pakken? Volgende online bronnen beveel ik aan om te volgen zodat je op de hoogte blijft van wat er allemaal gebeurt in de wereld van digitale stropers en boswachters.

5.1 Nieuws en blogartikels

- [DarkReading.com](#)
- [Fox It](#): zeer in-depth en technisch.
- [Graham Cluley blog](#)
- [Krebs on Security](#)
- [Troy Hunt](#): de blog van “Have I been pwnd”-oprichter Troy Hunt.

5.2 Podcasts

- [Darknet Diaries](#): waargebeurde “horror-verhalen” over het darknet, met boeiende, in-depth interviews met slachtoffers én aanvallers. Ik kan deze podcast niet genoeg aanbevelen!

5.3 Tutorials

- [Hacksplaining](#)
- [HackTricks book](#)

6 Appendix 2: Dark web

Het internet is vergelijkbaar met de echte wereld: het heeft goed verlichte plekken die iedereen kan zien, maar ook verborgen achterbuurten. Het Darkweb is zo'n verborgen gedeelte van het internet. Het maakt deel uit van het zogenaamde "Deep Web", dat gedeelte van het internet dat niet via standaard zoekmachines zoals Google te vinden is. Denk hierbij aan databanken, afgeschermdes websites en persoonlijke accounts die niet publiek toegankelijk zijn.

Binnen dat Deep Web bestaat een extra verborgen deel, het Darkweb, bekend om anonimiteit en privacy. Dit deel van het internet is alleen toegankelijk via speciale software zoals TOR (The Onion Router).



Figuur 6.1: De internet ijsberg

6.1 Kenmerken van het Darkweb

Het Darkweb onderscheidt zich van het reguliere internet door een aantal belangrijke kenmerken:

Anoniem: Gebruikers blijven anoniem doordat hun verbinding via meerdere tussenliggende servers loopt. Hierdoor is het zeer moeilijk te achterhalen wie een bepaalde website bezoekt of een bepaalde boodschap heeft verzonden.

Beveiligd: Communicatie en verkeer op het Darkweb zijn versleuteld met sterke encryptie. Dit voorkomt dat derden kunnen meekijken of informatie onderscheppen.

Gedecentraliseerd: Er is geen centrale autoriteit of punt van controle op het Darkweb. Dit maakt het moeilijk voor overheden en instanties om toezicht te houden, te censureren of sites uit de lucht te halen.

Zoals elke technologie kan ook het Darkweb gebruikt worden voor goede én slechte doeleinden:

- Slecht:
 - Handel in illegale goederen zoals drugs, wapens en gestolen informatie.
 - Verhuur van criminele diensten (“rent-a-hacker”).
- Goed:
 - Bescherming van privacy en anonieme communicatie.
 - Platforms voor journalisten, klokkenluiders en activisten om veilig te communiceren.

6.2 Waarom bestaat het Darkweb?

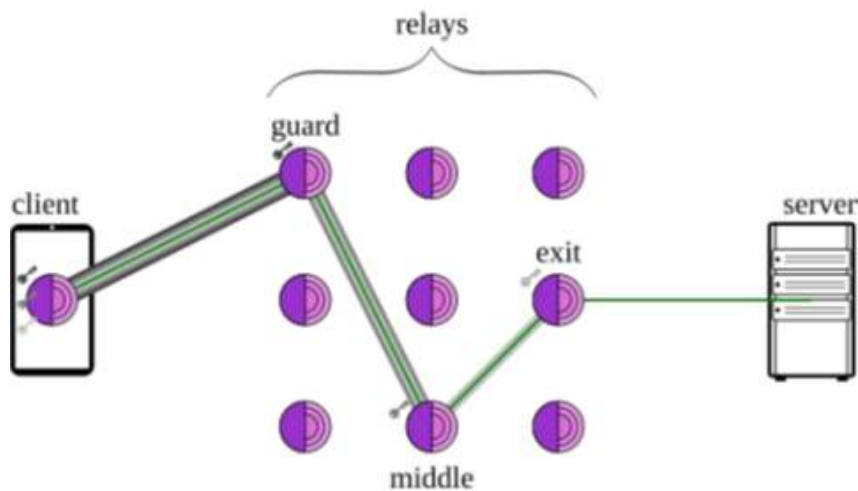
Het bestaan van het Darkweb roept veel vragen op over privacy en veiligheid. Aan de ene kant biedt het Darkweb een veilige ruimte voor mensen om zich vrij en anoniem te uiten. Dit kan van groot belang zijn voor journalisten, activisten en klokkenluiders die in landen leven met sterke censuur en toezicht (zoals China, Iran of Noord-Korea). Zo kan anonimiteit een cruciaal hulpmiddel zijn voor vrije meningsuiting en democratie.

Aan de andere kant trekt anonimiteit ook mensen aan die het internet gebruiken voor illegale activiteiten, zoals handel in drugs, wapens, gehackte gegevens, of gestolen creditcardgegevens.

Het Darkweb is dus niet per definitie illegaal, maar wat je erop doet kan dat wel zijn. In sommige landen, zoals Rusland en China, is het gebruik van het Darkweb zelf al strafbaar.

6.3 Toegang tot het Darkweb: TOR

De meest voorkomende manier om het Darkweb te bezoeken is via het zogenaamde TOR-netwerk (The Onion Router). Dit netwerk leidt jouw internetverkeer via meerdere relais-servers om jouw identiteit te verhullen. Een website op het Darkweb herken je aan het “.onion”-adres, wat alleen via een TOR-browser te openen is.



Figuur 6.2: Er worden letterlijk lagen, zoals een UI, tussen jou en je doel opgebouwd.

6.4 TOR heeft ook nadelen:

Snelheid: Het TOR-netwerk is relatief traag door de vele tussenstations.

Blokkades: Sommige websites blokkeren verkeer vanaf TOR-servers.

Firewall: Veel bedrijfsnetwerken en firewalls blokkeren verkeer van en naar het TOR-netwerk.

Er bestaan ook browsers, zoals Brave Browser, die TOR al geïntegreerd hebben, waardoor het gebruik eenvoudiger wordt.

6.5 Waarom moet je dit nu weten?

Het is belangrijk om inzicht te hebben in de risico's en kansen die het Darkweb biedt. Denk hierbij aan:

- Het begrijpen van criminele fenomenen zoals online drugshandel, cybercrime en mensenhandel.

- Het analyseren van bedreigingen en risico's voor organisaties en individuen.
- Het begrijpen van het belang van privacy, vrije meningsuiting, en de complexiteit van online toezicht en censuur.

Het Darkweb maakt dus deel uit van het bredere veiligheidsvraagstuk binnen de samenleving.



Vanwege tijdsgebrek werd deze appendix over het Darkweb grotendeels gegenereerd m.b.v. ChatGPT, gebaseerd op de slidedeck.

7 Appendix 3: Cybersecurity Awareness creëren

In dit hoofdstuk bekijken we de belangrijke rol die **cybersecurity-awareness** speelt binnen organisaties. Als cybersecurity-professionals zijn we ons bewust van de risico's, maar hoe zorgen we ervoor dat ook onze collega's deze risico's begrijpen en ernaar handelen? Dit hoofdstuk biedt inzicht in de noodzaak van awareness, de rol van medewerkers, en praktische tips om een cultuur van cybersecurity te bevorderen.

7.1 Waarom awareness?

De voorbije hoofdstukken hebben hopelijk al heel duidelijk gemaakt dat er zich nog te vaak cybersecurity-incidenten voordoen. Veel van die incidenten hadden eenvoudig kunnen worden voorkomen als werknemers (en gevers!) ook maar enige, minimale cybersecurity-awareness-training hadden gehad. Uit onderzoek blijkt dat ongeveer **90% van alle beveiligingsincidenten veroorzaakt wordt door menselijke fouten**, bewust of onbewust. Denk hierbij aan het klikken op phishing-links, het gebruiken van zwakke wachtwoorden, of het verbinden met onveilige wifi-netwerken. Deze menselijke factor maakt awareness onmisbaar binnen een robuust beveiligingsbeleid. Die laatste zin willen we nog even benadrukken: **bewustzijn is onmisbaar binnen een robuust beveiligingsbeleid**. Het is niet voldoende om alleen technische maatregelen te nemen; medewerkers moeten ook begrijpen waarom deze maatregelen belangrijk zijn en hoe ze deze kunnen toepassen in hun dagelijkse werkzaamheden.

7.1.1 Jouw rol binnen een organisatie

Jouw taak als cybersecurity expert gaat verder dan enkel systemen te configureren en onderhouden. Jij vormt ook de brug tussen IT en bedrijfsbeleid. Jij bent als het ware een **bewustzijnsambassadeur** die complexe technische informatie vertaalt naar begrijpelijke taal voor collega's.

Daarnaast heb je ook een signalerende rol:

- Identificeren van potentiële risico's.
- Rapporteren van afwijkingen of verdachte gebeurtenissen, en dit op een snelle en duidelijke manier.

7.1.2 Bescherm de hele keten: McCumber Cube

In hoofdstuk 2 bespraken we reeds de McCumber cube. Deze visualisatie helpt ons om in te zien dat we cybersecurity vanuit al z'n dimensies en facetten moeten bekijken. Hierbij waren de voorbije hoofdstukken vooral gericht op het technologie-aspect in functie van C.I.A en de staat van de data (processing, storage, transmission). In dit hoofdstuk gaan we daarom dieper in op de **menselijke** dimensie van cybersecurity. Dit is een cruciaal aspect dat vaak over het hoofd wordt gezien, maar dat net zo belangrijk is als de technische maatregelen die we nemen. De menselijke factor is immers de zwakste schakel in de beveiligingsketen. Daarom is het essentieel dat we ons richten op het creëren van een cultuur van cybersecurity-awareness binnen onze organisatie.

7.2 Awareness-campagnes

Om de medewerkers in een bedrijf te trainen in cybersecurity, zijn er verschillende methoden en technieken beschikbaar. Het doel van deze trainingen is om medewerkers bewust te maken van de risico's en hen te leren hoe ze veilig kunnen werken. Dit kan door middel van e-learning, workshops, of zelfs gamification. Het is belangrijk dat deze trainingen regelmatig worden herhaald, zodat medewerkers op de hoogte blijven van de laatste ontwikkelingen en trends op het gebied van cybersecurity.

Meestal gaan we dit doen aan de hand van, terugkerende, **awareness-campagnes**.

7.2.1 Gebruikersverwarring voorkomen

Losse technische maatregelen zijn niet voldoende. We moeten ook zorgen dat medewerkers begrijpen waarom deze maatregelen belangrijk zijn en hoe ze deze kunnen toepassen in hun dagelijkse werkzaamheden. Dit vereist een combinatie van technische kennis, communicatievaardigheden en leiderschap.

Medewerkers hebben namelijk vaak vragen zoals:

- “Waarom mag ik geen publiek wifi gebruiken?”
- “Waarom moet ik steeds opnieuw inloggen met multifactor-authenticatie (MFA)?”
- “Waarom moet ik mijn laptop vergrendelen?”

Het doel van awareness-campagnes is medewerkers zelfstandig antwoorden op deze vragen te laten geven. Niet door ze regels op te leggen, maar door ze inzicht te geven in de risico's en gevolgen van bepaalde gedragingen. Deze aanpak geldt trouwens eender waar in een omgeving waar er regels, wetten en procedures zijn. Het is niet voldoende om enkel te zeggen “dat mag niet”. We moeten ook uitleggen waarom iets niet mag en wat de gevolgen zijn van het negeren van deze regels.

Effectieve awareness-campagnes leggen dus niet enkel uit **wat** je moet doen, maar vooral ook **waarom**:

- Gebruikers leggen zelfstandig de link tussen risicogedrag en de mogelijke gevolgen.
- Ze maken bewust de keuze voor veilige werkmethoden.
- Veilig handelen wordt een routine, intrinsiek gemotiveerd door begrip.

Uiteindelijk willen we dat medewerkers autonoom zijn:

- Ze herkennen en rapporteren nieuwe risico's zelfstandig.
- Ze kunnen geleerde principes toepassen op onbekende situaties.

7.2.2 Succesvolle awareness-methoden

De mate waarin een campagne werkt hangt van vele factoren af. Het is belangrijk dat de campagne dan ook binnen de context van het bedrijf past: er is geen “one size fits all”. Hoe beter de campagne is afgestemd op het bedrijf en de medewerkers, hoe effectiever de campagne zal zijn. Gebruik met andere woorden realistische scenario's en voorbeelden die aansluiten bij de dagelijkse werkzaamheden van de medewerkers. Dit maakt het makkelijker voor hen om de informatie te begrijpen en toe te passen in hun eigen werk.

Alhoewel er tal van bedrijven zijn die awareness-campagnes aanbieden, zijn er ook een aantal goede gratis bronnen beschikbaar. Denk hierbij aan de website van de **SANS Institute** of de **Cybersecurity & Infrastructure Security Agency (CISA)**. Deze organisaties bieden gratis materialen en trainingen aan die bedrijven kunnen gebruiken om hun medewerkers bewust te maken van cybersecurity-risico's.

Enkele effectieve methodes voor cybersecurity-awareness zijn:

- **Regelmatige micro-trainingen:** korte, frequente sessies. Dit voorkomt dat medewerkers overweldigd worden door informatie en zorgt ervoor dat ze de informatie beter onthouden.
- **Phishing-simulaties:** directe feedback op acties zorgt voor snelle leerprocessen. Dit kan bijvoorbeeld door medewerkers te testen met nep-phishing-e-mails. Dit helpt hen om verdachte e-mails te herkennen en voorkomt dat ze in de val lopen van echte phishing-aanvallen.
- **Gamification:** quizzen en uitdagingen verhogen motivatie en betrokkenheid. Je zou bijvoorbeeld via een dashboard kunnen tonen welke dienst binnen het bedrijf het beste presteert op het gebied van cybersecurity-awareness. Dit kan medewerkers motiveren om beter op te letten en hun kennis te vergroten.
- **Posters en nieuwsbrieven met impact:** visuele reminders in de werkomgeving. Dit kan bijvoorbeeld door posters op te hangen met tips voor veilig werken of door het gebruik van stickers op laptops en andere apparaten. Dit zorgt ervoor dat medewerkers regelmatig worden herinnerd

aan de belangrijkste principes van cybersecurity. Als deze posters op de koop toe grappig, of zelfs uitdagend zijn, zullen medewerkers ze sneller opmerken en onthouden.



Figuur 7.1: Awareness posters hoeven geen ellenlange teksten te bevatten. Less is more.

- **Leiderschap:** het management moet het goede voorbeeld geven. Dit kan bijvoorbeeld door zelf ook regelmatig deel te nemen aan trainingen of door openlijk te praten over cybersecurity-risico's. Dit laat zien dat cybersecurity een prioriteit is binnen de organisatie en dat iedereen verantwoordelijk is voor het waarborgen van de veiligheid.



Gedragsverandering is vaak de moeilijkste uitdaging binnen cybersecurity. Positieve gedragsverandering bereik je niet door medewerkers te straffen of te bedreigen, maar door ze te motiveren en te inspireren.

7.3 Praktische best practices

Doorheen het handboek hebben we al tal van praktische “best practices” aangereikt. We vatten ze hier nog eens samen, daar zij de *backbone* zullen vormen van de inhoud van je awareness-campagnes. Dit zijn de basisprincipes die elke medewerker moet kennen en toepassen in zijn of haar dagelijkse werkzaamheden. Deze principes zijn niet alleen van toepassing op cybersecurity, maar ook op andere gebieden binnen een organisatie. Ze helpen medewerkers om veilig en efficiënt te werken, ongeacht hun functie of verantwoordelijkheden.

Wachtwoordhygiëne

- Gebruik sterke, unieke wachtwoorden.

- Maak gebruik van een wachtwoordmanager.
- Zet altijd multifactor-authenticatie aan.

Secuur apparaatbeheer

- Installeer automatische updates.
- Gebruik antivirussoftware.
- Vergrendel je laptop wanneer je weggaat.

Veilig werken met documenten en netwerken

- Vermijd onbekende USB-sticks en kabels.
- Gebruik enkel vertrouwde wifi-netwerken.
- Maak regelmatig backups van documenten, zowel fysiek als digitaal.

Blijf alert en leer verder

- Deel kennis actief binnen je team.
- Blijf bij met nieuwe ontwikkelingen op het gebied van cybersecurity.

7.4 Incident response

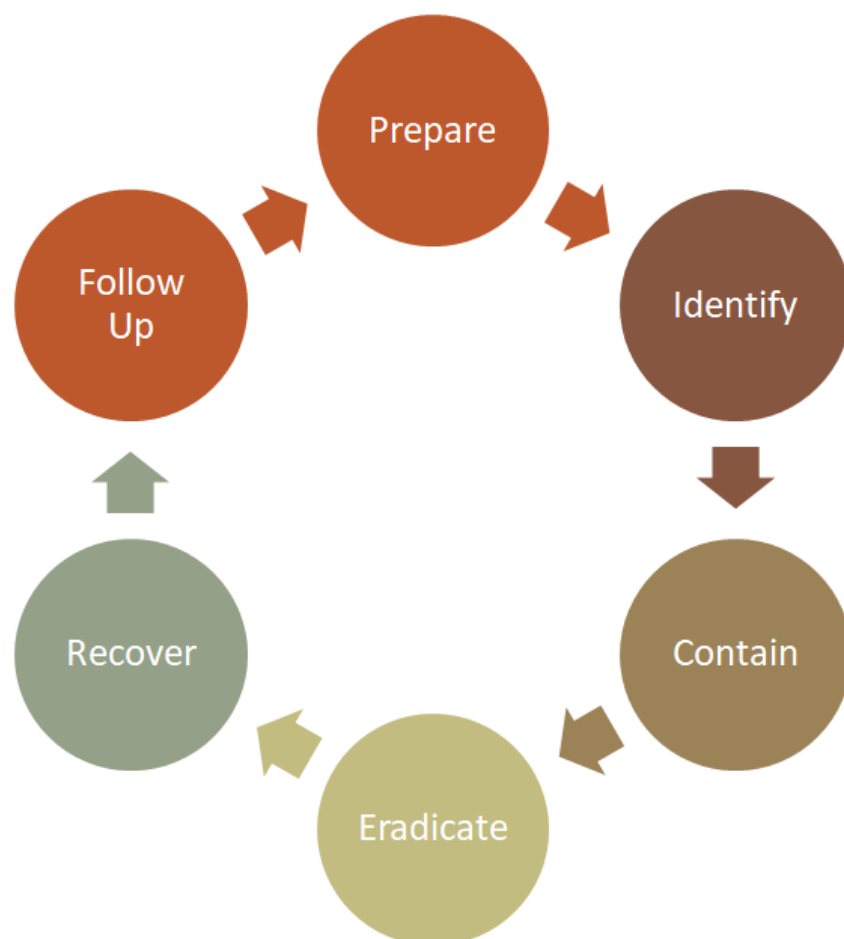
Awareness is ook cruciaal in incidentbeheer. Indien je medewerkers bewust zijn van de risico's en weten hoe ze moeten reageren op incidenten, kunnen ze sneller en effectiever handelen. Dit kan de impact van een incident aanzienlijk verminderen.

Incident response is een gestructureerde aanpak voor het afhandelen van beveiligingsincidenten. Het doel is om de schade te minimaliseren, de oorzaak van het incident te begrijpen, en herhaling in de toekomst te voorkomen. Een goed **incident response-plan** omvat duidelijke procedures, verantwoordelijkheden, en communicatiekanalen. Dergelijk plan bestaat uit verschillende stappen, die vaak worden weergegeven in een cyclus. De stappen zijn als volgt:

1. **Prepare:** Voorbereiden op incidenten vóór ze gebeuren. In deze fase worden alle procedures en verantwoordelijkheden gedefinieerd. Dit omvat ook het trainen van medewerkers in hoe ze moeten reageren op incidenten. Dit is waar awareness-campagnes een belangrijke rol spelen. Het incident response-plan moet meer zijn dan een document dat in de kast ligt. Het moet een levend document zijn dat regelmatig wordt bijgewerkt en waar medewerkers actief mee aan de slag gaan.
2. **Identify:** Incidenten snel herkennen. Dit kan door middel van monitoring, logging, en rapportage. Het is belangrijk dat medewerkers weten hoe ze verdachte activiteiten kunnen herkennen en

rapporteren. Dit kan bijvoorbeeld door het gebruik van een meldingsformulier of een speciaal meldpunt binnen de organisatie.

3. **Contain:** Beperk de schade direct na detectie. Dit kan door het isoleren van getroffen systemen of het blokkeren van verdachte accounts. Het is belangrijk dat medewerkers weten hoe ze snel kunnen handelen om verdere schade te voorkomen.
4. **Eradicate:** Verwijder het incident volledig. Vanaf deze, of de vorige stap zal meestal de IT-afdeling de verantwoordelijkheid nemen. Het is belangrijk dat medewerkers weten dat ze niet alleen verantwoordelijk zijn voor het melden van incidenten, maar ook voor het helpen bij het oplossen ervan. Dit kan bijvoorbeeld door het verzamelen van informatie over het incident of door het uitvoeren van bepaalde taken binnen de organisatie.
5. **Recover:** Herstel systemen en data.
6. **Follow Up:** Analyseer wat er is gebeurd en verbeter processen.



Figuur 7.2: Vaak wordt een incident response plan als een lineaire sequentie getoond, zonder te visualiseren dat er altijd na de followup informatie moet doorstromen naar de prepare fase. Op die manier leren we uit onze fouten, in de hoop dat deze volgende keer niet meer zullen voorkomen.

Awareness helpt vooral bij de **Identify** stap:

- Goede meldprocedures zijn dan ook cruciaal (wie, wat, hoe snel).
- Maak meldkanalen toegankelijk en laagdrempelig.
- Snelheid van identificatie bepaalt vaak de impact van een incident.



Het heeft geen nut om uiterst complexe incident response-plannen te maken, als medewerkers niet weten hoe ze deze moeten toepassen. Daarom is het belangrijk dat medewerkers goed op de hoogte zijn van de procedures en verantwoordelijkheden binnen het incident response-plan.



Het internet staat vol van nuttige hulpmiddelen om awareness campagnes uit te voeren. Gaande van toffe posters, tot *fullblown* phishing simulators (kijk zeker eens naar **GoPhish**). Met dank aan de immer krachtiger wordende mogelijkheden van ChatGPT en friends wordt het ook steeds eenvoudiger om succesvolle campagnes uit te werken en te visualiseren.

7.5 Social engineering en phishing

De eenvoudigste manier om medewerkers te hacken is door middel van social engineering. De aanvaller heeft hier namelijk geen tools of technieken voor nodig, enkel een goed verhaal. Social engineering is het manipuleren van mensen om vertrouwelijke informatie te verkrijgen of toegang te krijgen tot systemen. Dit kan bijvoorbeeld door middel van phishing-e-mails, waarbij de aanvaller zich voordoot als een vertrouwde bron om medewerkers te misleiden. Het is belangrijk dat medewerkers zich bewust zijn van deze risico's en weten hoe ze verdachte e-mails kunnen herkennen en rapporteren.

Omdat het leuk is om lijstjes te maken, hebben we hier een lijstje met de meest voorkomende social engineering technieken. Meestal zullen de digitale stropers een combinatie van deze technieken gebruiken om hun doel te bereiken.

- **Pretexting:** De aanvaller doet zich voor als iemand anders, bijvoorbeeld een collega of een IT-medewerker, om vertrouwelijke informatie te verkrijgen. Dit kan bijvoorbeeld door middel van een telefoongesprek of een e-mail. Meestal kan je dit herkennen aan de vraag om gevoelige informatie, zoals wachtwoorden of persoonlijke gegevens. Door een **challenge** te stellen, kan je de aanvaller vaak ontmaskeren. Vraag bijvoorbeeld om een bevestiging van de identiteit van de

persoon die je aan de lijn hebt. Dit kan bijvoorbeeld door middel van een terugbelprocedure of door het controleren van hun e-mailadres.

- **Tailgating:** De aanvaller volgt een medewerker naar binnen in een beveiligd gebied. Dit kan bijvoorbeeld door zich voor te doen als een medewerker of door simpelweg achter iemand aan te lopen. Dit kan je voorkomen door altijd je toegangspas te gebruiken en nooit iemand anders binnen te laten zonder hun identiteit te verifiëren. Het voelt soms lastig aan om een wildvreemde te vragen om zich te identificeren, maar het is beter om voorzichtig te zijn dan om een beveiligingsrisico te creëren.
- **Vishing:** Voice phishing, waarbij de aanvaller zich voordoeft als iemand anders via de telefoon. Dit kan bijvoorbeeld door zich voor te doen als een IT-medewerker of een bankmedewerker. Dit kan je herkennen aan verdachte vragen of verzoeken om persoonlijke informatie. Wees altijd voorzichtig met het delen van gevoelige informatie via de telefoon en verifieer altijd de identiteit van de persoon die je aan de lijn hebt. Doordat A.I. steeds beter wordt, is het ook mogelijk dat de aanvaller je stem kan imiteren. Dit maakt het nog moeilijker om te bepalen of je met een echte persoon of een nep persoon aan de lijn hebt. Meestal kan je de aanvaller ontmaskeren door ook nu weer een **challenge** te stellen. Je zou bijvoorbeeld een vraag uit het verleden kunnen stellen die enkel jij en de andere persoon kan weten. Als de persoon per ongeluk het juiste antwoord geeft dan kan je nog steeds doen alsof dit niet juist is om te zien of de aanvaller z'n correcte antwoord aanpast ("Uw bank is KBC", "Neem hoor (ook al is het dat wel)", "Oh excuses, ik bedoelde Argenta".) Deze vorm van challenge wordt ook wel ****reverse social engineering**** genoemd.
- **Baiting:** Deze techniek zal het slachtoffer lokken met iets dat hij echt wilt. Denk maar aan een USB-stick van het bedrijf, gratis een maand toegang tot Spotify Premium, etc. Van zodra je de *bait* aanvaardt, zal via deze weg meestal de aanval verder gezet worden (denk maar een virus dat op de USB-stick staat, of de link naar de gratis Spotify blijkt een link naar een malware server te zijn.) Het paard van Troje is een mooi voorbeeld van social engineering met behulp van *baiting*.
- **Quid Pro Quo:** 'Voor wat hoort wat'. De aanvaller zal een iets aanbieden (*bait*) maar dat enkel geven in ruil voor iets anders. Om bijvoorbeeld de bait te krijgen moet je eerst een vragenlijst invullen, maar in de vragenlijst staan ook vragen die je gevoelige informatie zullen ontfutselen ("Hoe heette je eerste huisdier"). Dit kan ook door bijvoorbeeld een gratis softwarepakket aan te bieden in ruil voor je e-mailadres of andere persoonlijke informatie.

Het is niet altijd eenvoudig om social engineering-aanvallen te herkennen, maar er zijn een aantal signalen waar je op kunt letten. Dit zijn enkele tips om verdachte e-mails of telefoontjes te herkennen:

- Controleer altijd het e-mailadres of telefoonnummer van de afzender. Dit kan je doen door het e-mailadres of telefoonnummer te vergelijken met eerdere communicatie of door het op te zoeken op de website van het bedrijf.
- Let op verdachte links of bijlagen in e-mails. Dit kan je doen door de muisaanwijzer boven de link

te houden zonder erop te klikken. Dit toont je waar de link naartoe leidt. Als de link er verdacht uitziet, klik er dan niet op.

- Wees voorzichtig met het delen van persoonlijke informatie. Dit kan je doen door altijd te vragen waarom de informatie nodig is en hoe deze zal worden gebruikt. Als je twijfelt, deel de informatie dan niet.
- Let op verdachte verzoeken of vragen. Dit kan je doen door altijd te vragen waarom de informatie nodig is en hoe deze zal worden gebruikt. Als je twijfelt, deel de informatie dan niet.

Bij twijfel kan je altijd een challenge stellen. En als je nog steeds twijfelt, doe dan een extra challenge, tot je overtuigd bent. Je zal verrassend vaak merken dat de aanvaller niet voorbereid is op deze extra vragen. En als blijkt dat de tegenpartij wel degelijk legitiem is, dan kan je altijd nog excuses aanbieden. Dit is een kleine prijs om te betalen voor de veiligheid van jezelf en je organisatie.

